

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



TIỂU LUẬN CUỐI KỲ
MÔN: BẢO MẬT TRONG IOT

NGHE LÉN DỮ LIỆU CẢM BIẾN
TRONG MẠNG IOT

Lớp học phần :	253INT441001
Giảng viên hướng dẫn:	Hồ Nhựt Minh
Sinh viên thực hiện:	Thi Võ Hoàng Huy
MSSV:	231A010454
Mã đề tài :	27

TP. HỒ CHÍ MINH - 2026

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



**TIỂU LUẬN CUỐI KỲ
MÔN: BẢO MẬT TRONG IOT**

**NGHE LÉN DỮ LIỆU CẢM BIẾN
TRONG MẠNG IOT**

Lớp học phần :	253INT441001
Giảng viên hướng dẫn:	Hồ Nhật Minh
Sinh viên thực hiện:	Thi Võ Hoàng Huy
MSSV:	231A010454
Mã đề tài :	27

TP. HỒ CHÍ MINH - 2026

LỜI CẢM ƠN

Em xin gửi lời cảm ơn chân thành nhất đến Ban Giám hiệu Trường Đại học Văn Hiến, cùng các thầy cô trong khoa Công nghệ thông tin đã tận tình giảng dạy, truyền đạt cho em những kiến thức quý báu trong suốt quá trình học tập. Những kiến thức đó là nền tảng vững chắc giúp em có thể áp dụng vào thực tiễn trong tương lai.

Em xin bày tỏ lòng biết ơn sâu sắc đến Giảng viên hướng dẫn Thầy Hồ Nhựt Minh, người đã tận tâm chỉ bảo và góp ý cho em trong suốt quá trình thực hiện bài tiểu luận. Sự hỗ trợ và hướng dẫn tận tình của thầy là nguồn động viên lớn giúp em hoàn thành tốt đề tài, bài tiểu luận này.

Cuối cùng, em xin chân thành cảm ơn tất cả mọi người đã giúp đỡ, động viên và đồng hành cùng em trong suốt quá trình học tập và thực hiện bài tiểu luận cuối kì.

Em xin chân thành cảm ơn!

LỜI CAM ĐOAN

Tôi xin cam đoan rằng đề tài " Nghe lén dữ liệu cảm biến trong mạng IoT" là kết quả của quá trình tìm hiểu, nghiên cứu và thực hiện của bản thân dưới sự hướng dẫn của giảng viên. Các nội dung trong báo cáo được xây dựng dựa trên kiến thức đã học, tài liệu tham khảo và quá trình triển khai, kiểm thử thực tế trong phạm vi đề tài.

Trong quá trình thực hiện báo cáo, tôi có sử dụng công cụ trí tuệ nhân tạo (AI) để hỗ trợ tìm hiểu kiến thức, gợi ý cách trình bày, diễn đạt nội dung và rà soát lỗi. Tuy nhiên, toàn bộ nội dung sau khi được AI hỗ trợ đều đã được tôi xem xét, chỉnh sửa và lựa chọn trước khi đưa vào báo cáo. Những phần sử dụng tài liệu từ các nguồn khác đều được trích dẫn theo quy định.

Tôi chịu hoàn toàn trách nhiệm về tính trung thực, chính xác của nội dung cũng như các số liệu, kết quả được trình bày trong báo cáo. Trường hợp có sai sót, bao gồm cả những thông tin hoặc số liệu do AI cung cấp nhưng chưa được kiểm chứng đầy đủ, tôi xin hoàn toàn chịu trách nhiệm và chấp nhận mọi hình thức xử lý theo quy định của nhà trường.

Tp.Hồ Chí Minh, ngày 31 tháng 07 năm 2026

Sinh viên thực hiện



Thi Võ Hoàng Huy

NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Tp.Hồ Chí Minh, ngày.....tháng.....năm.....

Giảng viên hướng dẫn

(Ký tên và ghi rõ họ tên)

MỤC LỤC

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI.....	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Vấn đề bảo mật.....	1
1.3. Mục tiêu của đề tài	1
1.4. Đối tượng, phạm vi và giới hạn an toàn.....	1
1.5. Sản phẩm và kết quả dự kiến.....	2
1.6. Cấu trúc báo cáo	2
Bảng đối chiếu mục tiêu và đầu ra	3
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN.....	4
2.1. Kiến trúc của hệ thống	4
2.2. Khái niệm bảo mật trực tiếp liên quan	4
2.3. Trọng tâm theo hướng của đề tài.....	5
2.4. Chuẩn, công cụ và nguồn GitHub chính	7
2.5. Công trình hoặc giải pháp liên quan.....	8
2.6. Tiểu kết.....	9
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ.....	10
3.1. Phương pháp thực hiện.....	10
3.2. Mô hình/kiến trúc hệ thống	10
3.3. Môi trường, công cụ và dữ liệu	11
3.4. Quy trình triển khai	12
3.5. Tiêu chí đánh giá.....	12
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ.....	14
4.1. Chuẩn bị môi trường	14
4.2. Thành phần sản phẩm.....	15
4.2.1. Cấu trúc repo và vai trò từng thư mục.....	15
4.2.2. Cách chạy thực nghiệm	16
4.3. Kịch bản thử nghiệm/áp dụng	17
Kịch bản TC-01 — Truyền dữ liệu thô (cleartext).....	17
Kịch bản TC-02 — Ký kèm HMAC với dữ liệu hợp lệ.....	18
Kịch bản TC-03 — HMAC phát hiện gói tin bị sửa	20
Kịch bản TC-04 — Mã hóa AES-256-GCM.....	21
Kịch bản TC-05 — AES-256-GCM phát hiện bản mã bị phá	22

Kịch bản TC-06 — Xác thực hợp lệ trên broker cục bộ	23
Kịch bản TC-07 — Chặn kết nối sai thông tin đăng nhập	24
Kịch bản TC-08 — Phân quyền ACL chặn ghi trái phép.....	24
4.4. Kết quả	25
4.5. Thảo luận và hạn chế.....	26
4.5.1. Thảo luận kết quả so với mục tiêu.....	26
4.5.2. Hạn chế.....	26
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT.....	27
5.1. Tài sản và dữ liệu cần bảo vệ	27
5.2. Môi đe dọa và lỗ hổng.....	27
5.3. Ma trận rủi ro	28
5.4. Biện pháp giảm thiểu.....	28
5.5. Rủi ro còn lại.....	29
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	30
6.1. Kết luận	30
6.2. Hạn chế.....	30
6.3. Hướng phát triển	30
TÀI LIỆU THAM KHẢO.....	31
PHỤ LỤC.....	32

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1	IoT	Internet of Things - vạn vật kết nối Internet
2	MQTT	Message Queuing Telemetry Transport - giao thức publish/subscribe dùng trong đề tài
3	HMAC	Hash-based Message Authentication Code - mã xác thực thông điệp có khóa
4	AES-GCM	Advanced Encryption Standard - Galois/Counter Mode - mã hóa có xác thực tích hợp
5	TLS	Transport Layer Security - giao thức bảo mật tầng vận chuyển
6	ACL	Access Control List - danh sách kiểm soát quyền truy cập
7	TC	Test Case - ca kiểm thử hay kịch bản kiểm thử.

DANH MỤC BẢNG BIỂU

Bảng 1.1. Đối chiếu mục tiêu và đầu ra	4
Bảng 2.1. Ánh xạ nhánh tấn công - STRIDE - điều kiện xảy ra - lớp phòng thủ	6
Bảng 2.2. Chuẩn, tài liệu và công cụ GitHub tham khảo	6
Bảng 2.3. So sánh các công trình, giải pháp liên quan	7
Bảng 3.1. Môi trường, công cụ và dữ liệu thử nghiệm	10
Bảng 3.2. Các bước quy trình triển khai và đánh giá	10
Bảng 3.3. Tiêu chí đánh giá và ngưỡng đạt	11
Bảng 4.1. Thành phần sản phẩm	14
Bảng 4.2. Tổng hợp kết quả các kịch bản kiểm thử	23
Bảng 5.1. Tài sản và dữ liệu cần bảo vệ	25
Bảng 5.2. Mối đe dọa và lỗ hổng theo mô hình STRIDE	25
Bảng 5.3. Ma trận rủi ro 5x5 (khả năng x tác động)	26
Bảng 5.4. Số đăng ký rủi ro và mức rủi ro còn lại sau xử lý	26

DANH MỤC HÌNH ẢNH

Hình 3.1. Kiến trúc mô hình lab và luồng đi của dữ liệu cảm biến (nguồn: tự vẽ)	9
Hình 3.2. Các cách gửi dữ liệu và thứ kẻ nghe lén thấy (nguồn: tự vẽ)	10
Hình 4.1. Mô hình triển khai thực nghiệm 2 máy: client trên Windows và broker Mosquitto trên máy ảo Ubuntu	13
Hình 4.2. Địa chỉ IP của máy Windows đóng vai trò client	13
Hình 4.3. Địa chỉ IP của máy ảo Ubuntu đóng vai trò broker	13
Hình 4.4. Máy Windows kiểm tra kết nối tới broker thành công (TcpTestSucceeded)	14
Hình 4.5. Khởi động broker Mosquitto ở chế độ hiển thị log chi tiết	15
Hình 4.6. Gửi data kịch bản cleartext - dữ liệu hiển thị dạng rõ	16
Hình 4.7. Nhận data kịch bản cleartext - dữ liệu hiển thị dạng rõ	16
Hình 4.8. Log của broker trong kịch bản truyền cleartext	17
Hình 4.9. Gửi data kịch bản HMAC với dữ liệu hợp lệ	17
Hình 4.10. Nhận data kịch bản HMAC với dữ liệu hợp lệ	18
Hình 4.11. Log của broker trong kịch bản truyền dữ liệu có HMAC	18
Hình 4.12. Publisher gửi dữ liệu hợp lệ ở chế độ HMAC trong kịch bản TC-03	19
Hình 4.13. Nhận data kịch bản HMAC phát hiện dữ liệu bị sửa	19
Hình 4.14. Log của broker trong kịch bản HMAC phát hiện gói tin bị sửa	19
Hình 4.15. Publisher gửi dữ liệu ở chế độ AES-256-GCM trong kịch bản TC-04	20
Hình 4.16. Kịch bản AES-256-GCM - mã hóa và giải mã thành công	20
Hình 4.17. Log của broker trong kịch bản mã hóa AES-256-GCM	20

Hình 4.18. Publisher gửi dữ liệu ở chế độ AES-256-GCM trong kịch bản TC-05.....	21
Hình 4.19. Kịch bản AES-256-GCM phát hiện ciphertext bị sửa.....	21
Hình 4.20. Log của broker trong kịch bản AES-256-GCM phát hiện bản mã bị phá...	21
Hình 4.21. Subscriber kết nối đến broker cục bộ thành công, có xác thực username/password.....	22
Hình 4.22. Publisher kết nối hợp lệ qua broker cục bộ có xác thực username/password	22
Hình 4.23. Broker từ chối kết nối do sai thông tin đăng nhập	22
Hình 4.24. Cơ chế ACL chặn thao tác ghi trái phép trên broker cục bộ	22
Hình 4.25. Log broker ghi nhận "Denied PUBLISH from subscriber_user" kèm mã lý do 135	23

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Trong các hệ thống IoT hiện đại, thiết bị cảm biến (nhiệt độ, độ ẩm, trạng thái vận hành...) thường gửi dữ liệu định kỳ về gateway hoặc server thông qua giao thức MQTT do tính nhẹ, tiết kiệm băng thông và phù hợp với thiết bị tài nguyên hạn chế (OASIS, MQTT Version 5.0 Specification, 2019). Trong nhiều triển khai thực tế, đặc biệt ở mức thử nghiệm hoặc chi phí thấp, payload MQTT vẫn được truyền dưới dạng văn bản rõ (cleartext) mà không qua lớp bảo vệ TLS. Khi đó, bất kỳ thiết bị nào cùng phân đoạn mạng Wi-Fi công cộng hoặc LAN đều có thể bắt gói tin và đọc trực tiếp nội dung bản tin, bao gồm device_id, nhiệt độ, độ ẩm, vị trí hoặc trạng thái thiết bị (OWASP, IoT Security Verification Standard - ISVS, 2023).

Đối tượng chịu ảnh hưởng trực tiếp là người dùng sở hữu thiết bị IoT gia đình/công nghiệp nhỏ và đơn vị vận hành hệ thống giám sát, vì dữ liệu cảm biến bị lộ có thể tiết lộ thói quen sinh hoạt, tình trạng thiết bị hoặc tạo điều kiện cho các tấn công tiếp theo (sửa đổi dữ liệu, giả mạo thiết bị). Đề tài được thực hiện nhằm minh họa cụ thể rủi ro nghe lén này trên một mô hình MQTT thu nhỏ, từ đó đề xuất và kiểm chứng các biện pháp phòng chống tương ứng.

1.2. Vấn đề bảo mật

Tài sản cần bảo vệ là dữ liệu cảm biến (nhiệt độ, độ ẩm, trạng thái thiết bị) và định danh thiết bị (device_id) được trao đổi giữa publisher (thiết bị cảm biến giả lập) và subscriber (server/ứng dụng giám sát) qua kênh MQTT. Mỗi đe dọa chính là nghe lén (eavesdropping) khi payload truyền ở dạng cleartext; hai mối đe dọa liên quan là sửa đổi dữ liệu (tampering) khi gói tin không có cơ chế toàn vẹn, và giả mạo thiết bị (spoofing) khi broker không yêu cầu xác thực/ACL.

Hậu quả gồm: rò rỉ thông tin riêng tư và trạng thái thiết bị; sai lệch dữ liệu vận hành dẫn đến báo động giả hoặc quyết định điều khiển sai; nguy cơ thiết bị giả mạo làm nhiễu hệ thống. Khoảng trống mà đề tài xử lý: chưa có minh chứng thực nghiệm trực quan (log, ảnh chụp) so sánh mức độ lộ thông tin giữa ba phương án cleartext, HMAC-SHA256 và AES-256-GCM, nên đề tài xây dựng demo cụ thể để lấp khoảng trống này.

1.3. Mục tiêu của đề tài

- MT-01: Minh họa bằng thực nghiệm việc dữ liệu cảm biến MQTT truyền dạng cleartext có thể bị đọc trực tiếp khi bị nghe lén.
- MT-02: Xây dựng demo publisher/subscriber bằng Python (thư viện Eclipse Paho MQTT) mô phỏng thiết bị cảm biến.
- MT-03: So sánh ba chế độ truyền dữ liệu - cleartext, HMAC-SHA256 (toàn vẹn) và AES-256-GCM (bí mật + toàn vẹn) - thông qua log thực nghiệm.
- MT-04: Phân tích các mối đe dọa liên quan (nghe lén, sửa đổi dữ liệu, giả mạo thiết bị, phát lại) và đề xuất biện pháp phòng chống tương ứng.

1.4. Đối tượng, phạm vi và giới hạn an toàn

Đối tượng nghiên cứu: giao thức MQTT (mô hình publish/subscribe) và dữ liệu cảm biến giả lập (nhiệt độ, độ ẩm, trạng thái thiết bị) trao đổi giữa publisher và subscriber.

Phạm vi thực hiện: môi trường lab an toàn, dùng broker công khai test.mosquitto.org hoặc Mosquitto cài cục bộ, toàn bộ dữ liệu là dữ liệu mô phỏng (không thu thập từ thiết bị hoặc người dùng thật). Ba chế độ bảo vệ dữ liệu được triển khai và so sánh (cleartext, HMAC-SHA256, AES-256-GCM); ngoài ra đề tài triển khai và kiểm chứng cơ chế xác thực username/password kết hợp ACL ở tầng broker cục bộ.

Giới hạn an toàn: đề tài không thực hiện tấn công vào hệ thống mạng thật, không nghe lén dữ liệu của bên thứ ba, và không triển khai trên thiết bị IoT vật lý đang sản xuất thực tế; mọi kịch bản tấn công (sửa đổi gói tin, giả mạo) đều được mô phỏng bằng tham số --simulate-attack trong mã nguồn tự viết.

Đề tài tuân thủ nghiêm ngặt các giới hạn an toàn và đạo đức sau:

- Hệ thống được phép thử nghiệm: chỉ mô hình MQTT do sinh viên tự dựng (publisher, subscriber, broker cục bộ) hoặc broker công khai test.mosquitto.org với topic riêng của đề tài.
- Loại dữ liệu được dùng: hoàn toàn là dữ liệu cảm biến giả lập; không thu thập, không nghe lén dữ liệu của người dùng hoặc bên thứ ba.
- Xử lý secret: khóa HMAC/AES trong mã chỉ mang tính minh họa; repo không chứa mật khẩu, token hay dữ liệu cá nhân thật; file configs/passwd chỉ là mẫu, mật khẩu thật được sinh cục bộ bằng mosquitto_passwd và không commit.
- Hành động bị cấm: không quét hay tấn công hệ thống mạng thật, không triển khai trên thiết bị IoT đang vận hành thực tế; mọi kịch bản tấn công (sửa gói tin, giả mạo) đều được mô phỏng bằng tham số --simulate-attack trong môi trường cục bộ.

1.5. Sản phẩm và kết quả dự kiến

Sản phẩm kỹ thuật: mã nguồn Python (src/publisher.py, src/subscriber.py, src/utils.py) triển khai ba chế độ cleartext/HMAC/AES-GCM; cấu hình Mosquitto (mosquitto.conf, aclfile, passwd); dữ liệu giả lập (dataset_gia_lap.csv, payload_mau.json).

Sản phẩm phân tích: bảng đánh giá rủi ro nghe lén/sửa đổi/giả mạo/replay, sơ đồ luồng bảo vệ dữ liệu (Mermaid).

1.6. Cấu trúc báo cáo

Cấu trúc báo cáo gồm sáu chương:

- Chương 1 nêu bối cảnh, phát biểu vấn đề bảo mật, mục tiêu, phạm vi và sản phẩm dự kiến của đề tài.
- Chương 2 trình bày phần cơ sở lý thuyết được dùng trực tiếp trong bài: kiến trúc MQTT và ranh giới tin cậy, các khái niệm bảo mật, danh mục chuẩn - công cụ - nguồn GitHub và các giải pháp liên quan.
- Chương 3 mô tả phương pháp thực hiện, mô hình lab đề xuất, môi trường công cụ, quy trình triển khai và tiêu chí đánh giá.
- Chương 4 trình bày quá trình triển khai, tám kịch bản thử nghiệm kèm log và ảnh minh chứng, kết quả đo được đối chiếu với tiêu chí ở Mục 3.5, cùng phần thảo luận và hạn chế.
- Chương 5 đánh giá kết quả thực nghiệm
- Chương 6 kết luận theo từng mục tiêu, nêu hạn chế và hướng phát triển.

Bảng đối chiếu mục tiêu và đầu ra

Bảng 1.1. Đối chiếu mục tiêu và đầu ra

Mục tiêu	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
MT-01	Log và ảnh chụp cho thấy payload cleartext bị đọc trực tiếp	Kịch bản TC-01: đối chiếu results/logs/cleartext_traffic.log với ảnh terminal subscriber	Chương 4
MT-02	Mã nguồn src/publisher.py, src/subscriber.py, src/utlis.py chạy được trên broker thật	Chạy lại TC-01→TC-05 trên broker Mosquitto cục bộ và kiểm tra dữ liệu tới subscriber	Chương 3, Chương 4
MT-03	Bảng tổng hợp so sánh ba chế độ bảo vệ kèm log của từng chế độ	Đối chiếu Bảng 4.2 với results/logs/secure_traffic.log và results/output.csv	Chương 4
MT-04	Bảng tài sản, bảng mối đe dọa - lỗ hổng, ma trận rủi ro 5x5 và danh mục biện pháp	Kiểm chứng thực tế qua TC-06→TC-08 (xác thực, ACL); đối chiếu STRIDE và checklist OWASP ISVS	Chương 5

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc của hệ thống

Mô hình lab gồm ba thành phần: (1) Publisher giả lập thiết bị cảm biến (DHT22-SENSOR-001), sinh payload JSON gồm nhiệt độ, độ ẩm và device_id theo chu kỳ; (2) MQTT Broker (Eclipse Mosquitto, dùng broker công khai test.mosquitto.org hoặc bản cài cục bộ với cấu hình Username/Password và ACL) đóng vai trò trung chuyển bản tin theo topic `iot/sensor/data`; (3) Subscriber đóng vai trò server giám sát, nhận payload, kiểm tra cơ chế bảo vệ (HMAC hoặc AES-GCM) và ghi log.

Luồng dữ liệu tổng quát: Thiết bị cảm biến giả lập -> MQTT Broker -> Subscriber kiểm tra dữ liệu. Ranh giới tin cậy nằm giữa publisher/subscriber (do sinh viên kiểm soát) và đường truyền mạng công khai đi qua broker - đây là vị trí kẻ tấn công (nghe lén) được giả định có thể quan sát lưu lượng.

2.2. Khái niệm bảo mật trực tiếp liên quan

2.2.1. Tài sản, mối đe dọa, lỗ hổng và rủi ro

Tài sản là thành phần có giá trị cần được bảo vệ; mối đe dọa là sự kiện bất lợi có thể xảy ra với tài sản; lỗ hổng là điểm yếu cho phép mối đe dọa trở thành hiện thực; rủi ro là kết hợp của khả năng xảy ra và mức tác động. Trong đề tài, tài sản gồm dữ liệu cảm biến (nhiệt độ, độ ẩm), định danh thiết bị device_id, khóa HMAC/AES và tài khoản truy cập broker (Bảng 5.1). Ví dụ, mối đe dọa nghe lén dữ liệu cảm biến (T-01) trở thành hiện thực nhờ lỗ hổng payload truyền dạng cleartext, tạo ra rủi ro R-01 với điểm 16 tương ứng mức Cao (Bảng 5.4).

2.2.2. Bộ ba CIA

CIA là khung tham chiếu gồm Confidentiality (tính bí mật — chỉ bên được phép mới đọc được dữ liệu), Integrity (tính toàn vẹn — dữ liệu không bị thay đổi trái phép) và Availability (tính sẵn sàng — dịch vụ luôn truy cập được khi cần). Đề tài tập trung vào hai yếu tố đầu vì rủi ro trọng tâm là nghe lén và sửa đổi bản tin; tính sẵn sàng chỉ được ghi nhận, không thử nghiệm tấn công từ chối dịch vụ. Cụ thể, tính bí mật được bảo vệ bằng mã hóa AES-256-GCM (kịch bản TC-04) và tính toàn vẹn bằng HMAC-SHA256 (kịch bản TC-02 và TC-03).

2.2.3. Ranh giới tin cậy và giả định về kẻ tấn công

Ranh giới tin cậy (trust boundary) là đường phân chia giữa vùng hệ thống kiểm soát được và vùng không kiểm soát được; mọi dữ liệu đi qua ranh giới này đều phải coi là có thể bị quan sát hoặc bị can thiệp. Trong mô hình lab (Hình 3.1), publisher và subscriber nằm trong vùng tin cậy do sinh viên kiểm soát, còn broker và đường truyền mạng nằm ngoài vùng đó. Kẻ tấn công được giả định có khả năng quan sát lưu lượng đi qua ranh giới, và ở các kịch bản nâng cao là can thiệp được vào nội dung bản tin, nhưng không chiếm quyền điều khiển máy publisher hay subscriber.

2.2.4. Nghe lén và bản tin dạng rõ (cleartext)

Nghe lén (eavesdropping) là hành vi đọc trộm dữ liệu trên đường truyền mà không làm thay đổi dữ liệu, nên cả bên gửi lẫn bên nhận đều không phát hiện được. Điều kiện để nghe lén thành công là bản tin ở dạng rõ, tức chuỗi ký tự đọc được trực tiếp mà không qua mã hóa. Giao thức MQTT mặc định không mã hóa payload (OASIS, 2019), vì vậy ở kịch bản TC-01 toàn bộ JSON gồm device_id, temperature và humidity hiển thị nguyên vẹn cả trên terminal subscriber lẫn trong log của broker (Hình 4.6 đến Hình 4.8).

2.2.5. Tính toàn vẹn và HMAC-SHA256

HMAC (Hash-based Message Authentication Code, RFC 2104) là mã xác thực thông điệp dùng khóa bí mật chia sẻ: bên gửi tính chữ ký từ nội dung bản tin cùng khóa rồi gửi kèm, bên nhận tính lại và so sánh. Chỉ cần nội dung thay đổi một ký tự thì chữ ký không khớp, nên bên nhận phát hiện được ngay; tuy nhiên HMAC chỉ bảo vệ tính toàn vẹn, dữ liệu vẫn đọc được bình thường. Trong đề tài, chữ ký được tính trên chuỗi JSON đã chuẩn hóa (hàm canonical_json trong src/utlis.py) để kết quả không phụ thuộc thứ tự các trường; kịch bản TC-03 mô phỏng bản tin bị sửa và subscriber báo "XÁC THỰC HMAC THẤT BẠI" (Hình 4.13).

2.2.6. Mã hóa có xác thực và AES-256-GCM

Mã hóa đối xứng là phương pháp dùng chung một khóa cho cả mã hóa và giải mã. AES-256-GCM (NIST SP 800-38D) thuộc nhóm mã hóa có xác thực AEAD (Authenticated Encryption with Associated Data): ngoài bản mã, thuật toán còn sinh một authentication tag để bên nhận kiểm tra bản mã có bị can thiệp hay không. Nhờ vậy AES-256-GCM bảo vệ đồng thời tính bí mật và tính toàn vẹn, thay thế được vai trò của HMAC trong cùng một bước xử lý. Ở kịch bản TC-04, dữ liệu trên đường truyền chỉ còn chuỗi Base64 vô nghĩa; ở TC-05, khi bản mã bị phá thì quá trình giải mã thất bại và subscriber báo "LỖI GIẢI MÃ" (Hình 4.19).

2.2.7. Mô hình đe dọa STRIDE

STRIDE là mô hình phân loại mối đe dọa gồm sáu nhóm: Spoofing (giả mạo danh tính), Tampering (sửa đổi dữ liệu), Repudiation (chối bỏ hành vi), Information Disclosure (lộ thông tin), Denial of Service (từ chối dịch vụ) và Elevation of Privilege (leo thang đặc quyền); mô hình này giúp rà soát có hệ thống, tránh bỏ sót loại đe dọa nào khi phân tích

2.3. Trọng tâm theo hướng của đề tài

Đề tài số 27 thuộc hướng D, vì vậy phần cơ sở lý thuyết tập trung vào mô hình tấn công, điều kiện để tấn công xảy ra, tác động và các lớp phòng thủ, thay vì trình bày

dàn trải kiến trúc IoT nói chung. Mục này mô tả cây tấn công của đề tài rồi ánh xạ từng nhánh sang mô hình STRIDE để làm cơ sở cho phần đánh giá rủi ro ở Chương 5.

Mô hình tấn công (attack tree) với mục tiêu gốc "Đọc hoặc làm sai lệch dữ liệu cảm biến truyền trên kênh MQTT" được phân thành bốn nhánh:

A. Nghe lén trực tiếp lưu lượng MQTT

A1. Kẻ tấn công ở cùng phân đoạn LAN hoặc Wi-Fi với publisher/broker rồi bắt gói tin ở cổng 1883.

A2. Kẻ tấn công kết nối tới broker và subscribe vào topic không bị giới hạn quyền đọc.

B. Xen giữa và sửa đổi bản tin (tampering)

B1. Chiếm đường truyền trong LAN (ví dụ ARP spoofing) rồi thay đổi trường temperature trước khi bản tin tới subscriber.

B2. Chèn bản tin giả vào topic khi bên nhận không có cơ chế kiểm tra toàn vẹn payload.

C. Giả mạo thiết bị (spoofing)

C1. Dùng một client bất kỳ publish vào topic của hệ thống khi broker cho phép kết nối ẩn danh.

C2. Dùng lại tài khoản bị lộ hoặc tài khoản dùng chung giữa nhiều thiết bị.

D. Phát lại bản tin cũ (replay)

D1. Ghi lại một bản tin hợp lệ rồi gửi lại nhiều lần vì payload không chứa timestamp hoặc nonce.

Điều kiện xảy ra chung của cả bốn nhánh là kênh MQTT không được mã hóa ở tầng vận chuyển và bản tin không có cơ chế xác thực nguồn gốc. Nhánh A chỉ cần kẻ tấn công quan sát được lưu lượng; nhánh B cần thêm khả năng can thiệp vào đường truyền; nhánh C cần broker cấu hình lỏng (allow_anonymous true, không có ACL, hoặc mật khẩu yếu); nhánh D chỉ cần bản tin không có yếu tố chống lặp.

Tác động trải trên cả ba yếu tố của bộ ba CIA: mất tính bí mật khi device_id, nhiệt độ và độ ẩm bị đọc, từ đó suy ra thói quen sinh hoạt hoặc trạng thái vận hành của thiết bị; mất tính toàn vẹn khi dữ liệu bị sửa dẫn tới báo động giả và quyết định điều khiển sai; giảm mức tin cậy của hệ thống giám sát khi thiết bị giả bơm dữ liệu rác vào cùng một topic.

Phòng thủ nhiều lớp được đề tài áp dụng gồm ba lớp độc lập: lớp bản tin (HMAC-SHA256 cho toàn vẹn, AES-256-GCM cho cả bí mật và toàn vẹn), lớp broker (xác thực username/password kết hợp ACL tối thiểu quyền) và lớp vận chuyển (TLS ở cổng 8883, nêu ở phần hướng phát triển). Nguyên tắc là một lớp bị vô hiệu thì các lớp còn lại vẫn giữ được tài sản, thay vì phụ thuộc hoàn toàn vào TLS.

Bảng 2.1. Ánh xạ nhánh tấn công - STRIDE - điều kiện xảy ra - lớp phòng thủ

Nhóm STRIDE	Nhánh	Điều kiện xảy ra	Tác động	Lớp phòng thủ tương ứng
Information Disclosure	A1, A2	Payload dạng cleartext, không bật TLS; kẻ tấn công quan sát được lưu lượng hoặc subscribe được topic	Lộ device_id, nhiệt độ, độ ẩm; suy ra thói quen và trạng thái thiết bị	Mã hóa payload AES-256-GCM; TLS cổng 8883; ACL giới hạn quyền đọc topic
Tampering	B1, B2	Bản tin không kèm mã xác thực; broker chỉ chuyển tiếp, không kiểm tra nội dung	Dữ liệu vận hành sai lệch, báo động giả, quyết định điều khiển sai	HMAC-SHA256; authentication tag của AES-GCM
Spoofing	C1, C2	allow_anonymous true hoặc mật khẩu yếu/dùng chung; không có ACL theo tài khoản	Thiết bị giả bơm dữ liệu rác vào hệ thống giám sát	Xác thực username/password (TC-06, TC-07); mTLS bằng chứng thư client
Elevation of Privilege	C1	Tài khoản chỉ cần quyền đọc nhưng được cấp cả quyền ghi trên topic	Client giám sát có thể ghi đè dữ liệu hoặc gửi lệnh sai	ACL tách quyền read/write theo từng tài khoản (kiểm chứng ở TC-08)
Replay	D1	Payload không chứa timestamp hoặc nonce; bên nhận không lưu trạng thái đã nhận	Dữ liệu cũ được ghi nhận như dữ liệu mới, làm sai lịch sử đo	Thêm timestamp/nonce kèm cửa sổ thời gian hợp lệ ở phía nhận

2.4. Chuẩn, công cụ và nguồn GitHub chính

Bảng 2.2. Chuẩn, tài liệu và công cụ GitHub tham khảo

ST T	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
1	Eclipse Mosquitto	https://github.com/eclipse-mosquitto/mosquitto	MQTT Broker dùng để dựng lab và cấu hình xác thực/ACL	17/07/2026
2	Eclipse Paho Python Client	https://github.com/eclipse-paho/paho.mqtt.python	Thư viện Python viết publisher/subscriber MQTT	17/07/2026
3	OWASP IoT Security Verification Standard (ISVS)	https://github.com/OWASP/iot-security-verification-standard	Checklist kiểm tra bảo mật IoT ở mức truyền tải và dữ liệu	17/07/2026

4	RFC 2104 - HMAC	https://datatracker.ietf.org/doc/html/rfc2104	Cơ sở lý thuyết HMAC-SHA256 chống sửa đổi payload	17/07/2026
5	NIST SP 800-38D - AES-GCM	https://csrc.nist.gov/publications/detail/sp/800-38d/final	Cơ sở lý thuyết AES-GCM bảo vệ bí mật và toàn vẹn	17/07/2026

2.5. Công trình hoặc giải pháp liên quan

Ba nguồn gần nhất với đề tài được khảo sát gồm hai công cụ mã nguồn mở (Eclipse Mosquitto và Eclipse Paho Python Client) và một khung tiêu chí kiểm định (OWASP IoT Security Verification Standard). Bảng 2.3 so sánh mục tiêu, cách làm, ưu điểm, hạn chế và phần mà đề tài kế thừa từ mỗi nguồn.

Bảng 2.3. So sánh các công trình, giải pháp liên quan

Tiêu chí so sánh	Eclipse Mosquitto	Eclipse Paho Python Client	OWASP IoT Security Verification Standard (ISVS)
Mục tiêu	Cung cấp broker MQTT nhẹ, hỗ trợ xác thực và phân quyền	Cung cấp thư viện client MQTT cho Python	Đưa ra bộ tiêu chí xác minh bảo mật cho hệ thống IoT
Cách làm	Cấu hình listener, password_file và acl_file; ghi log sự kiện kết nối và từ chối	Mô hình callback on_connect/on_message; hỗ trợ username_pw_set và TLS	Checklist theo nhóm: giao tiếp, lưu trữ, xác thực, cập nhật thiết bị
Ưu điểm	Chuẩn công nghiệp, tài liệu đầy đủ, log rõ ràng nên thuận lợi thu minh chứng	API ngắn gọn, dễ chèn thêm lớp xử lý payload trước khi gửi và sau khi nhận	Tiêu chí kiểm chứng được, phù hợp để đối chiếu mức đáp ứng của từng chế độ truyền
Hạn chế	Mặc định cho phép kết nối ẩn danh và không bắt TLS nên rất dễ triển khai sai	Không có sẵn cơ chế bảo vệ bí mật hay toàn vẹn ở mức bản tin	Là khung tiêu chí, không kèm mã mẫu hay công cụ thực thi nên phải tự dựng lab
Phần đề tài kế thừa	Dùng làm broker cho toàn bộ lab; kế thừa cơ chế password_file và acl_file cho TC-06→TC-08	Dùng viết publisher và subscriber; đề tài bổ sung lớp HMAC-SHA256 và AES-256-GCM lên trên	Dùng đối chiếu mức đáp ứng của ba chế độ truyền và làm căn cứ lập bảng đe dọa ở Chương 5

Khoảng trống mà đề tài lấp: cả ba nguồn trên đều dừng ở mức cung cấp công cụ hoặc tiêu chí, chưa đưa ra minh chứng thực nghiệm trực quan so sánh mức độ lộ thông tin giữa payload cleartext, payload có HMAC và payload được mã hóa AES-GCM trên cùng một tập dữ liệu. Đề tài kế thừa công cụ của Mosquitto/Paho và tiêu chí của OWASP

ISVS, sau đó bổ sung lớp bảo vệ ở tầng payload cùng bộ tám kịch bản thử nghiệm có log và ảnh minh chứng, nhằm minh họa nguyên tắc phòng thủ nhiều lớp thay vì chỉ dựa vào TLS ở tầng vận chuyển.

2.6. Tiểu kết

Chương 2 đã giới hạn phần kiến thức nền vào đúng những gì được dùng trực tiếp trong bài: kiến trúc publisher - broker - subscriber của MQTT cùng ranh giới tin cậy, bộ ba CIA, HMAC-SHA256, AES-256-GCM và mô hình STRIDE, cây tấn công bốn nhánh theo hướng D kèm ánh xạ sang STRIDE, điều kiện xảy ra, tác động và lớp phòng thủ, danh mục chuẩn và nguồn GitHub được sử dụng, các giải pháp liên quan và khoảng trống mà đề tài lấp. Ba lớp bảo vệ được xác định - bảo vệ ở tầng bản tin, xác thực và phân quyền ở tầng broker, mã hóa kênh ở tầng vận chuyển - chính là cơ sở để Chương 3 thiết kế mô hình lab, chọn công cụ, xây dựng quy trình thử nghiệm và đặt ra tiêu chí đánh giá cho từng kịch bản.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài sử dụng phương pháp lab mô phỏng kết hợp kiểm thử theo kịch bản (scenario-based testing) và phân tích rủi ro ở tầng giao thức. Cụ thể gồm năm hướng tiếp cận sau:

- Xây dựng lab MQTT thu nhỏ gồm ba thành phần publisher – broker – subscriber để tái hiện đường đi thực tế của dữ liệu cảm biến, thay cho việc can thiệp vào hệ thống thật.
- Kiểm thử theo ba kịch bản bảo vệ tầng dần (cleartext, HMAC-SHA256 và AES-256-GCM) trên cùng một tập dữ liệu giả lập để so sánh khác quan mức độ lộ thông tin và khả năng phát hiện sửa đổi.
- Kiểm thử xác thực và phân quyền ở tầng broker: dựng broker Mosquitto cục bộ có username/password và ACL, kiểm chứng việc từ chối đăng nhập sai (Not authorized) và chặn ghi trái phép (Denied PUBLISH).
- Mô phỏng tấn công có kiểm soát bằng tham số --simulate-attack trong mã nguồn tự viết (sửa giá trị nhiệt độ với HMAC, phá hoại ciphertext với AES-GCM), tuyệt đối không tấn công hệ thống bên ngoài.
- Phân tích rủi ro theo mô hình STRIDE cho ba mối đe dọa Information Disclosure (nghe lén), Tampering (sửa đổi) và Spoofing (giả mạo), đối chiếu với checklist OWASP ISVS.

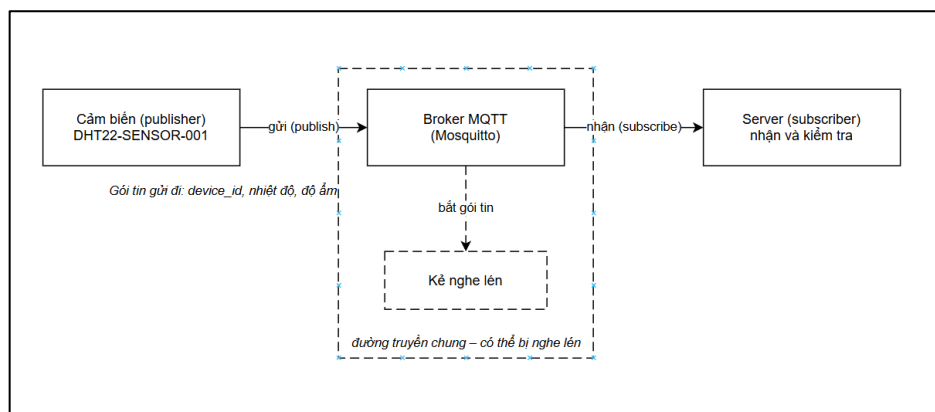
Kết quả mỗi kịch bản được thu thập tự động dưới dạng log (results/logs/) và bảng dữ liệu subscriber lưu lại (results/output.csv), bổ sung ảnh chụp màn hình làm minh chứng.

3.2. Mô hình/kiến trúc hệ thống

Mô hình lab được minh họa ở Hình 3.1, gồm ba thành phần chính:

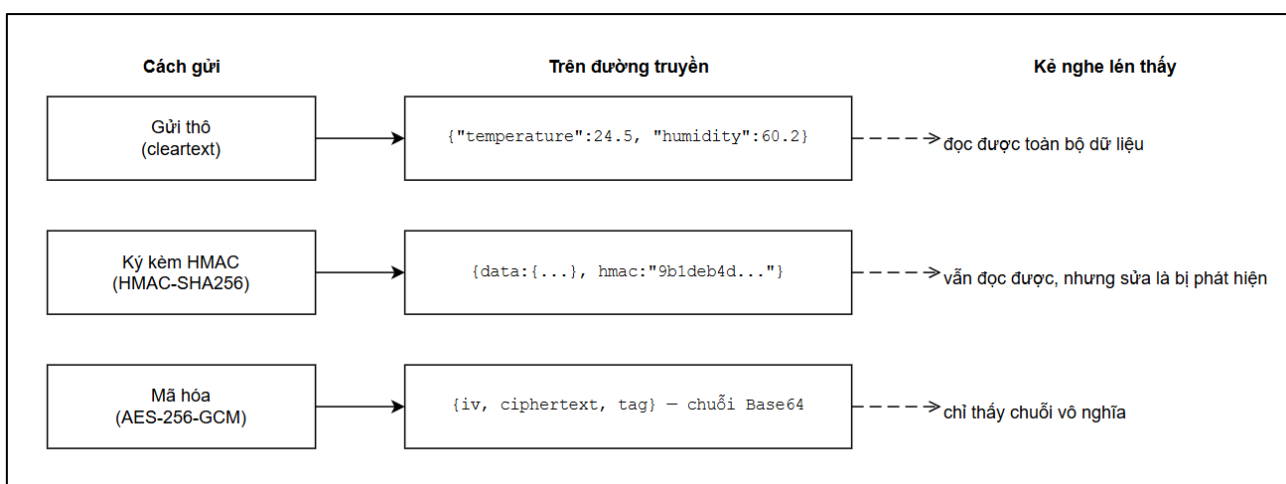
- Publisher – thiết bị cảm biến giả lập DHT22-SENSOR-001, đọc dữ liệu từ data/dataset_gia_lap.csv và sinh payload JSON gồm device_id, temperature, humidity, status theo chu kỳ.
- MQTT Broker – Eclipse Mosquitto, trung chuyển bản tin theo topic `iot/sensor/data`.
- Subscriber – server giám sát, nhận payload, kiểm tra cơ chế bảo vệ (HMAC hoặc AES-GCM) và ghi log.

Luồng dữ liệu tổng quát: Publisher → MQTT Broker → Subscriber. Ranh giới tin cậy (trust boundary) nằm giữa hai vùng: publisher và subscriber do sinh viên kiểm soát, còn broker và đường truyền mạng công khai nằm ngoài vùng tin cậy – đây là vị trí kẻ tấn công được giả định có thể quan sát lưu lượng và bắt gói tin. Dữ liệu nhạy cảm cần bảo vệ gồm device_id, temperature và humidity.



Hình 3.1. Kiến trúc mô hình lab và luồng đi của dữ liệu cảm biến (nguồn: tự vẽ)

Ba mức bảo vệ payload được so sánh ở Hình 3.2: cleartext (không bảo vệ), HMAC-SHA256 (chống sửa đổi) và AES-256-GCM (chống nghe lén và chống sửa đổi).



Hình 3.2. Các cách gửi dữ liệu và thứ kẻ nghe lén thấy (nguồn: tự vẽ)

3.3. Môi trường, công cụ và dữ liệu

Bảng 3.1. Môi trường, công cụ và dữ liệu thử nghiệm

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
Python	3.14	Ngôn ngữ chạy publisher/subscriber	Chạy cục bộ trên máy sinh viên
paho-mqtt	2.1.0	Thư viện client MQTT (Eclipse Paho)	Cài qua pip, không cần quyền admin
cryptography	49.0.0	Cung cấp mã hóa AES-256-GCM	Khóa chỉ dùng minh họa, không phải khóa thật
Eclipse Mosquitto	2.x / test.mosquitto.org	MQTT Broker: bản cục bộ cho kịch bản ACL, broker công khai để chạy nhanh	Bản cục bộ lắng nghe cổng 1883 trên mọi giao diện (0.0.0.0), allow_anonymous false, có xác thực và ACL
Máy ảo Ubuntu	24.04.4 LTS	Chạy broker Mosquitto cục bộ (xác thực + ACL)	Mạng nội bộ (Bridged/Host-only) với

			máy Windows, tách khỏi mạng thật
dataset_gia_lap.csv	—	Dữ liệu cảm biến giả lập (nhiệt độ, độ ẩm)	Hoàn toàn mô phỏng, không có dữ liệu thật

3.4. Quy trình triển khai

Bảng 3.2. Các bước quy trình triển khai

Bước	Công việc	Đầu ra	Minh chứng trong repo
1	Cài môi trường (pip install paho-mqtt cryptography), chuẩn bị dữ liệu giả lập	Môi trường chạy được	data/dataset_gia_lap.csv
2	Chạy kịch bản cleartext: publisher gửi JSON rõ, subscriber nhận	Dữ liệu đọc được trực tiếp trên đường truyền	results/logs/cleartext_traffic.log; ảnh cleartext_demo.png
3	Chạy kịch bản HMAC-SHA256 (thường và --simulate-attack)	Xác thực thành công / phát hiện sửa đổi	results/logs/secure_traffic.log; ảnh hmac_ok.png, hmac_attack.png
4	Chạy kịch bản AES-256-GCM (thường và --simulate-attack)	Ciphertext trên đường truyền / lỗi giải mã khi bị phá	ảnh aes_ok.png, aes_attack.png
5	Chạy kịch bản giả mạo/ACL trên broker Mosquitto cục bộ	Broker từ chối user/topic sai	TC-06→TC-08; results/screenshots/spoofing_blocked.png; results/logs/mosquitto.log
6	Tổng hợp log, lập bảng so sánh và ma trận rủi ro	Bảng kết quả, sơ đồ luồng	results/output.csv, README.md, Hình 3.1 và 3.2

3.5. Tiêu chí đánh giá

Kết quả thực nghiệm được đánh giá theo tám tiêu chí đo được dưới đây, mỗi tiêu chí có ngưỡng đạt rõ ràng để đối chiếu trực tiếp ở Mục 4.4. Các tiêu chí được đặt mã TĐ-01 đến TĐ-08 nhằm phân biệt với mã kịch bản thử nghiệm TC-01 đến TC-08.

Bảng 3.3. Tiêu chí đánh giá và ngưỡng đạt

Tiêu chí	Cách đo	Ngưỡng đạt
Tỷ lệ kịch bản cho kết quả đúng kỳ vọng	Số kịch bản có kết quả trùng kỳ vọng chia cho tổng số kịch bản TC-01→TC-08	8/8 kịch bản đúng kỳ vọng
Khả năng đọc payload khi nghe lén	Đếm số trường dữ liệu đọc được trực tiếp trên đường truyền (device_id, temperature, humidity, status)	Cleartext: 4/4 trường đọc được; AES-256-GCM: 0/4 trường đọc được

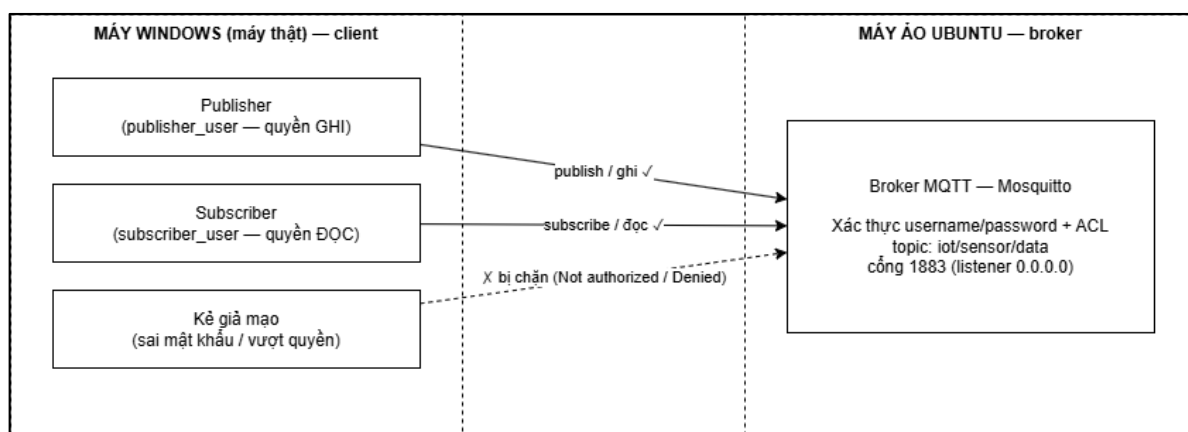
Khả năng phát hiện bản tin bị sửa	Số lần bên nhận báo lỗi khi bản tin bị can thiệp bằng tham số --simulate-attack	100% bản tin bị sửa đều bị phát hiện (HMAC thất bại hoặc lỗi giải mã)
Tỷ lệ báo sai với dữ liệu hợp lệ	Số bản tin hợp lệ bị báo lỗi chia cho tổng bản tin hợp lệ ở chế độ hmac và encrypted	0% - không có bản tin hợp lệ nào bị báo sai
Hiệu lực xác thực ở tầng broker	Mã trả về trong gói CONNACK khi đăng nhập đúng và khi đăng nhập sai	Tài khoản đúng: rc = 0; sai mật khẩu: broker trả "Not authorized"
Hiệu lực phân quyền ACL	Kết quả khi tài khoản chỉ có quyền đọc cố gắng publish lên topic	Broker ghi log "Denied PUBLISH" kèm mã 135 và subscriber không nhận được gói tin
Mức đầy đủ của minh chứng	Mỗi kịch bản có ít nhất một ảnh chụp và một dòng log tương ứng trong repo	8/8 kịch bản có đủ cả ảnh và log
Mức giảm rủi ro trước và sau xử lý	So sánh mức rủi ro của R-01→R-06 trước và sau khi áp biện pháp (Bảng 5.4)	Toàn bộ rủi ro mức Cao giảm về Trung bình hoặc Thấp

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

Thực nghiệm sử dụng mô hình hai máy: một máy ảo Ubuntu đóng vai trò máy chủ trung gian (broker) chạy Eclipse Mosquitto cục bộ, và một máy Windows thật đóng vai trò các client gồm publisher, subscriber và máy giả mạo. Dữ liệu cảm biến được giả lập nên không cần thiết bị IoT vật lý. Các bước chuẩn bị như sau:

- Trên máy Windows: cài Python 3 và hai thư viện cần thiết bằng lệnh `pip install paho-mqtt cryptography`; tải mã nguồn từ repo về máy và giữ nguyên cấu trúc thư mục (src, configs, data, results).
- Trên máy ảo Ubuntu: cài Eclipse Mosquitto, sinh tài khoản bằng lệnh `mosquitto_passwd` và nạp cấu hình xác thực cùng danh sách phân quyền từ thư mục configs (mosquitto.conf, aclfile, passwd).
- Đặt hai máy trong cùng dải mạng nội bộ (chế độ Bridged hoặc Host-only, trong thực nghiệm là Bridged) để máy Windows kết nối tới broker qua địa chỉ IP của máy ảo trên cổng 1883.



Hình 4.1. Mô hình triển khai thực nghiệm 2 máy: client trên Windows và broker Mosquitto trên máy ảo Ubuntu

+ Ở đây máy windows (máy thật) có địa chỉ IP như sau:

```
Wireless LAN adapter Wi-Fi:

Connection-specific DNS Suffix . : 
Link-local IPv6 Address . . . . . : fe80::9808:5224:b7d4:35a7%19
IPv4 Address. . . . . : 192.168.1.2
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.1.1
```

Hình 4.2. Địa chỉ IP của máy Windows đóng vai trò client

+ Máy Guest (VM- Ubuntu) có địa chỉ IP như sau:

```
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:83:fb:f6 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.1.6/24 metric 100 brd 192.168.1.255 scope global dynamic ens33
        valid_lft 3515sec preferred_lft 3515sec
    inet6 fe80::20c:29ff:fe83:fbf6/64 scope link
        valid_lft forever preferred_lft forever
```

Hình 4.3. Địa chỉ IP của máy ảo Ubuntu đóng vai trò broker

Máy windows (client) đã kết nối với broker thành công:

```
PS C:\Users\USER> Test-NetConnection 192.168.1.6 -Port 1883

ComputerName      : 192.168.1.6
RemoteAddress     : 192.168.1.6
RemotePort        : 1883
InterfaceAlias    : Wi-Fi
SourceAddress     : 192.168.1.2
TcpTestSucceeded  : True
```

Hình 4.4. Máy Windows kiểm tra kết nối tới broker thành công (TcpTestSucceeded)

Ban đầu ba kịch bản cơ bản (cleartext, HMAC, AES-GCM) được thử nhanh trên broker công khai test.mosquitto.org; tuy nhiên broker công khai không cho phép cấu hình xác thực và phân quyền, nên toàn bộ kịch bản — đặc biệt nhóm xác thực và ACL — được hoàn thiện trên broker Mosquitto cục bộ.

Chi tiết lệnh chạy được trình bày ở Mục 4.2 và trong README của repo.

4.2. Thành phần sản phẩm

Bảng 4.1. Thành phần sản phẩm

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
1	publisher.py	src/publisher.py	Giả lập cảm biến, gửi payload theo ba chế độ bảo vệ	Thi Võ Hoàng Huy
2	subscriber.py	src/subscriber.py	Nhận payload, kiểm tra HMAC/giải mã AES và ghi log	Thi Võ Hoàng Huy
3	utils.py	src/utils.py	Hàm HMAC-SHA256 và mã hóa AES-256-GCM	Thi Võ Hoàng Huy
4	Cấu hình Mosquitto	configs/mosquitto.conf, aclfile, passwd	Xác thực username/password và ACL cho broker cục bộ	Thi Võ Hoàng Huy
5	Dữ liệu giả lập	data/dataset_gia_lap.csv, payload_mau.json	Dữ liệu cảm biến và bản tin mẫu trước/sau bảo vệ	Thi Võ Hoàng Huy
6	Kết quả thực nghiệm	results/logs/, output.csv, screenshots/	Log, bảng dữ liệu nhận được và ảnh minh chứng	Thi Võ Hoàng Huy

4.2.1. Cấu trúc repo và vai trò từng thư mục

Sản phẩm được tổ chức trong repo theo cấu trúc sau:

```

De_tai_27-Nghe_len_du_lieu_trong_mang_IoT/
├── README.md # Mô tả đề tài, cấu trúc thư mục và cách chạy
├── requirements.txt # Thư viện Python cần cài (paho-mqtt, cryptography)
├── src/ # Mã nguồn Python
│   ├── publisher.py # Cảm biến giả lập: đọc CSV, gửi payload 3 chế độ
│   ├── subscriber.py # Bên nhận: kiểm HMAC / giải mã AES, ghi log
│   └── utils.py # HMAC-SHA256, AES-256-GCM, canonical_json
├── configs/ # Cấu hình broker Mosquitto cục bộ
│   ├── mosquitto.conf # Bật xác thực và ACL, cấu hình log
│   ├── aclfile # publisher_user: ghi, subscriber_user: đọc
│   └── passwd # File mật khẩu (tạo bằng mosquitto_passwd)
├── data/ # Dữ liệu đầu vào
│   ├── dataset_gia_lap.csv # Dữ liệu DHT22 giả lập (nhiệt độ, độ ẩm)
│   └── payload_mau.json # Bản tin mẫu trước và sau khi bảo vệ
├── results/ # Kết quả thực nghiệm - minh chứng
│   ├── logs/ # Log lưu lượng phía client
│   │   ├── cleartext_traffic.log # Log kịch bản TC-01
│   │   └── secure_traffic.log # Log kịch bản TC-02 đến TC-05
│   ├── output.csv # Dữ liệu subscriber nhận + trạng thái toàn vẹn
│   └── screenshots/ # 10 ảnh chụp terminal các kịch bản
├── report/
│   ├── 231A010454_ThiVoHoangHuy_DeTai27_TieuLuan_CuoiKy.docx
│   └── 231A010454_ThiVoHoangHuy_DeTai27_TieuLuan_CuoiKy.pdf
├── slides/
│   ├── 231A010454_ThiVoHoangHuy_DeTai27_Slide.pptx.pptx
│   └── 231A010454_ThiVoHoangHuy_DeTai27_Slide.pdf
├── references/ # Nguồn tham khảo
└── link_nguon.md

```

Vai trò từng thư mục: src chứa toàn bộ mã nguồn ba chế độ bảo vệ; configs chứa cấu hình broker gồm listener, tệp mật khẩu và danh sách phân quyền; data chứa dữ liệu cảm biến giả lập và bản tin mẫu trước - sau khi bảo vệ; results là nơi thu minh chứng gồm log của client, log broker, ảnh chụp terminal và bảng dữ liệu subscriber ghi lại; report chứa tệp nguồn draw.io của Hình 3.1, Hình 3.2 và bản báo cáo; slides chứa slide bảo vệ; references lưu bản sao các tài liệu chuẩn đã trích dẫn; README.md mô tả đề tài, cấu trúc thư mục và cách chạy; requirements.txt khai báo hai thư viện paho-mqtt và cryptography.

4.2.2. Cách chạy thực nghiệm

Nhóm kịch bản bảo vệ dữ liệu cần hai cửa sổ terminal phía client: một chạy subscriber (bên nhận) và một chạy publisher (bên gửi), với tham số --mode trùng nhau.

- Bên nhận: `python src/subscriber.py --mode cleartext`
- Bên gửi: `python src/publisher.py --mode cleartext`
- Đổi --mode thành hmac hoặc encrypted để chạy hai chế độ còn lại; thêm --simulate-attack ở subscriber để kiểm chứng cơ chế phát hiện sửa đổi.
- Nhóm kịch bản xác thực và phân quyền dùng broker cục bộ: trên máy ảo Ubuntu chạy `mosquitto -c configs/mosquitto.conf -v`; trên máy Windows trỏ client tới broker bằng tham số `--broker <IP_may_ao>` kèm `--username` và `--password` (ví dụ tài khoản `publisher_user` hoặc `subscriber_user`).

Điều kiện tái hiện: phía client có Python 3 với hai thư viện paho-mqtt và cryptography; phía máy chủ có một broker MQTT — broker công khai để thử nhanh, hoặc Mosquitto cục bộ có bật xác thực và ACL cho nhóm kịch bản nâng cao. Hướng dẫn đầy đủ nằm trong README của repo.

4.3. Kịch bản thử nghiệm/áp dụng

Đề tài thực hiện tám kịch bản thử nghiệm, chia thành hai nhóm: Nhóm A bảo vệ dữ liệu ở mức bản tin (TC-01 đến TC-05) và Nhóm B xác thực, phân quyền ở tầng broker cục bộ (TC-06 đến TC-08). Mỗi kịch bản đều kèm ảnh chụp màn hình làm minh chứng.

Đầu tiên khởi động broker bằng lệnh nhập tại terminal: “**mosquitto -c configs/mosquitto.conf -v**”

```
huy@huy:~/De_tai_27-Nghe_len_du_lieu_trong_mang_IoT$ mosquitto -c configs/mosquitto.conf -v
1784899395: mosquitto version 2.0.18 starting
1784899395: Config loaded from configs/mosquitto.conf.
1784899395: Warning: File configs/aclfile has world readable permissions. Future versions will refuse to load this file.
To fix this, use 'chmod 0700 configs/aclfile'.
1784899395: Opening ipv4 listen socket on port 1883.
1784899395: mosquitto version 2.0.18 running
1784899523: New connection from 192.168.1.2:62965 on port 1883.
1784899523: New client connected from 192.168.1.2:62965 as auto-D0C483B3-4F8C-E843-283C-014FCA298297 (p2, c1, k60, u'subscriber_user').
```

Hình 4.5. Khởi động broker Mosquitto ở chế độ hiển thị log chi tiết

Tại máy windows mở sẵn 2 cửa sổ shell khác nhau đóng vai trò là publisher và subscriber.

Kịch bản TC-01 — Truyền dữ liệu thô (cleartext)

- Mục tiêu: chứng minh dữ liệu rõ bị lộ khi bị nghe lén
- Thao tác: chạy subscriber và publisher ở chế độ cleartext

Tại shell publisher gõ “**py src\publisher.py --mode cleartext --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data**” để gửi data ở chế độ cleartext.

```
PS C:\Users\USER> cd "D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki"
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode cleartext --broker 192.168.1.6 --
--username publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [CLEARTEXT]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "s
tatus": "OK"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "s
tatus": "OK"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity": 60.0, "s
tatus": "OK"}

[Gửi gói tin #4] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:15Z", "device_id": "DHT22-SENSOR-001", "temperature": 25.0, "humidity": 59.8, "s
tatus": "OK"}
```

Hình 4.6. Gửi data kịch bản cleartext - dữ liệu hiển thị dạng rõ

Tại shell subscriber gõ “**py src\subscriber.py --mode cleartext --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data**” để nhận data.

Ở đây có hiện cảnh báo data đang được truyền dưới dạng cleartext.

```

PS C:\Users\USER> cd "D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki"
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode cleartext --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:26:06.910130
[*] Raw payload chụp được từ đường truyền MQTT:
{"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "status": "OK"}
=====
[!] CẢNH BÁO: Dữ liệu đang được truyền dưới dạng Rõ (Cleartext)!
[+] Thiết bị ID: DHT22-SENSOR-001
[+] Nhiệt độ: 24.5°C | Độ ẩm: 60.2%
[+] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:26:08.911259
[*] Raw payload chụp được từ đường truyền MQTT:
{"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "status": "OK"}
=====
[!] CẢNH BÁO: Dữ liệu đang được truyền dưới dạng Rõ (Cleartext)!
[+] Thiết bị ID: DHT22-SENSOR-001

```

Hình 4.7. Nhận data kịch bản cleartext - dữ liệu hiển thị dạng rõ

```

1784899566: New connection from 192.168.1.2:62806 on port 1883.
1784899566: New client connected from 192.168.1.2:62806 as auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (p2, c1, k60, u'publisher_user').
1784899566: No will message specified.
1784899566: Sending CONNACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (0, 0)
1784899566: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m1, 'iot/sensor/data', ... (125 bytes))
1784899566: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899566: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m1, rc0)
1784899568: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m2, 'iot/sensor/data', ... (125 bytes))
1784899568: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899568: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m2, rc0)
1784899570: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m3, 'iot/sensor/data', ... (125 bytes))
1784899570: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899570: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m3, rc0)
1784899572: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m4, 'iot/sensor/data', ... (125 bytes))
1784899572: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899572: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m4, rc0)
1784899574: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m5, 'iot/sensor/data', ... (125 bytes))
1784899574: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899574: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m5, rc0)
1784899576: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m6, 'iot/sensor/data', ... (125 bytes))
1784899576: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))

```

Hình 4.8. Log của broker trong kịch bản truyền cleartext

- Kết quả quan sát: subscriber hiển thị JSON rõ, ai bắt gói tin cũng đọc được toàn bộ nhiệt độ và độ ẩm

Kịch bản TC-02 — Ký kèm HMAC với dữ liệu hợp lệ

- Mục tiêu: kiểm chứng tính toàn vẹn khi dữ liệu không bị sửa
- Thao tác: chạy chế độ hmac ở trạng thái bình thường

Tại shell publisher gõ “py src\publisher.py --mode hmac --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data” để gửi data bằng chế độ hmac

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode hmac --broker 192.168.1.6 --user
name publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [HMAC]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity":
60.2, "status": "OK"}, "hmac": "0d3227730bdc71e2cc39fec64504e053858519137676195dbf1b759d6935e287"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity":
60.1, "status": "OK"}, "hmac": "3b2e5c4f0bb9aa2a588d4b530b1e4b80e96b6b9f83b2808b51375aa527f8cff8"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity":
60.0, "status": "OK"}, "hmac": "2f499a2d3f72e0b6bd1f41f7b5f3ef6949923cd1a5f54c1e081b3ea4d47d4837"}

[Gửi gói tin #4] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:15Z", "device_id": "DHT22-SENSOR-001", "temperature": 25.0, "humidity":
59.8, "status": "OK"}, "hmac": "d46773856bce0ee0859d3fb7bc5eb108b982255a4a8149ea8446011d0c6f617a"}

```

Hình 4.9. Gửi data kịch bản HMAC với dữ liệu hợp lệ

Tại shell subscriber gõ “py src\subscriber.py --mode hmac --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data” để nhận data.

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode hmac --broker 192.168.1.6 --username su
bscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:42:30.552358
[*] Raw payload chụp được từ đường truyền MQTT:
{"data": {"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "
status": "OK"}, "hmac": "0d3227730bdc71e2cc39fec64504e053858519137676195dbf1b759d6935e287"}
=====
[+] XÁC THỰC HMAC THÀNH CÔNG: Dữ liệu toàn vẹn và đúng nguồn gốc!
[+] Thiết bị ID: DHT22-SENSOR-001
[+] Nhiệt độ: 24.5°C | Độ ẩm: 60.2%
[*] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:42:32.558482
[*] Raw payload chụp được từ đường truyền MQTT:
{"data": {"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "
status": "OK"}, "hmac": "3b2e5c4f0bb9aa2a588d4b530b1e4b80e96b6b9f83b2808b51375aa527f8cff8"}
=====

```

Hình 4.10. Nhận data kịch bản HMAC với dữ liệu hợp lệ

- Kết quả quan sát: subscriber báo "XÁC THỰC HMAC THÀNH CÔNG"

```

huy@huy:~/De_tai_27-Nghe_len_du_lieu_trong_mang_IoT$ mosquitto -c configs/mosquitto.conf -v
1784900522: mosquitto version 2.0.18 starting
1784900522: Config loaded from configs/mosquitto.conf.
1784900522: Warning: File configs/aclfile has world readable permissions. Future versions will refuse to load this file.
To fix this, use 'chmod 0700 configs/aclfile'.
1784900522: Opening ipv4 listen socket on port 1883.
1784900522: mosquitto version 2.0.18 running
1784900537: New connection from 192.168.1.2:59176 on port 1883.
1784900537: New client connected from 192.168.1.2:59176 as auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6 (p2, c1, k60, u'subscriber_user').
1784900537: No will message specified.
1784900537: Sending CONNACK to auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6 (0, 0)
1784900537: Received SUBSCRIBE from auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6
1784900537: iot/sensor/data (QoS 0)
1784900537: auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6 0 iot/sensor/data
1784900537: Sending SUBACK to auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6
1784900549: New connection from 192.168.1.2:59180 on port 1883.
1784900549: New client connected from 192.168.1.2:59180 as auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (p2, c1, k60, u'publisher_user').
1784900549: No will message specified.
1784900549: Sending CONNACK to auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (0, 0)
1784900549: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (d0, q1, r0, m1, 'iot/sensor/data', ... (211 bytes))
1784900549: Sending PUBLISH to auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6 (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784900549: Sending PUBACK to auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (m1, rc0)
1784900551: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (d0, q1, r0, m2, 'iot/sensor/data', ... (211 bytes))
1784900551: Sending PUBLISH to auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6 (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784900551: Sending PUBACK to auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (m2, rc0)
1784900553: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (d0, q1, r0, m3, 'iot/sensor/data', ... (211 bytes))
1784900553: Sending PUBLISH to auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6 (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784900553: Sending PUBACK to auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (m3, rc0)
1784900555: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (d0, q1, r0, m4, 'iot/sensor/data', ... (211 bytes))
1784900555: Sending PUBLISH to auto-03BDAA58-6CCC-89EC-E919-ED70B9640BE6 (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784900555: Sending PUBACK to auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (m4, rc0)
1784900557: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B888F2566D04 (d0, q1, r0, m5, 'iot/sensor/data', ... (211 bytes))

```

Hình 4.11. Log của broker trong kịch bản truyền dữ liệu có HMAC

Kịch bản TC-03 — HMAC phát hiện gói tin bị sửa

- Mục tiêu: phát hiện dữ liệu bị thay đổi trên đường truyền
- Thao tác: chạy chế độ hmac với tham số --simulate-attack

Tại shell của publisher gõ “py src\publisher.py --mode hmac --broker 192.168.1.6 -username publisher_user --password 123 --topic iot/sensor/data”

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode hmac --broker 192.168.1.6 --user
name publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [HMAC]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity":
60.2, "status": "OK"}, "hmac": "0d3227730bdc71e2cc39fec64504e053858519137676195dbf1b759d6935e287"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity":
60.1, "status": "OK"}, "hmac": "3b2e5c4f0bb9aa2a588d4b530b1e4b80e96b6b9f83b2808b51375aa527f8cff8"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity":
60.0, "status": "OK"}, "hmac": "2f499a2d6f372e0b6bd1f41f7b5f3ef6949923cd1a5f54c1e081b3ea4d47d4837"}

```

Hình 4.12. Publisher gửi dữ liệu hợp lệ ở chế độ HMAC trong kịch bản TC-03

Tại shell của subscriber gõ “py src\subscriber.py --mode hmac --simulate-attack --broker 192.168.1.6 --username subscriber_user --password sub123 --topic iot/sensor/data”

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode hmac --simulate-attack --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:59:39.745943
[*] Raw payload chụp được từ đường truyền MQTT:
{"data": {"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "status": "OK"}, "hmac": "0d3227730bdc71e2cc39fec64504e053858519137676195dbf1b759d6935e287"}
=====
[!] Tấn công giả lập: Đang sửa đổi giá trị nhiệt độ trong gói tin...
[-] XÁC THỰC HMAC THẤT BẠI: Phát hiện dữ liệu đã bị sửa đổi trái phép trên đường truyền!
[+] Thiết bị ID: DHT22-SENSOR-001
[+] Nhiệt độ: 99.9°C | Độ ẩm: 60.2%
[*] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv
=====

```

Hình 4.13. Nhận data kịch bản HMAC phát hiện dữ liệu bị sửa

- Kết quả quan sát: subscriber báo "XÁC THỰC HMAC THẤT BẠI"

```

1784901578: New connection from 192.168.1.2:60137 on port 1883.
1784901578: New client connected from 192.168.1.2:60137 as auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (p2, c1, k60, u'publisher_user').
1784901578: No will message specified.
1784901578: Sending CONNACK to auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (0, 0)
1784901578: Received PUBLISH from auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (d0, q1, r0, m1, 'iot/sensor/data', ... (211 bytes))
1784901578: Sending PUBLISH to auto-37FDFD2A-CE25-0459-F79F-3B2187266D7C (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784901578: Sending PUBACK to auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (m1, rc0)
1784901580: Received PUBLISH from auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (d0, q1, r0, m2, 'iot/sensor/data', ... (211 bytes))
1784901580: Sending PUBLISH to auto-37FDFD2A-CE25-0459-F79F-3B2187266D7C (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784901580: Sending PUBACK to auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (m2, rc0)
1784901582: Received PUBLISH from auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (d0, q1, r0, m3, 'iot/sensor/data', ... (211 bytes))
1784901582: Sending PUBLISH to auto-37FDFD2A-CE25-0459-F79F-3B2187266D7C (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784901582: Sending PUBACK to auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (m3, rc0)
1784901584: Received PUBLISH from auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (d0, q1, r0, m4, 'iot/sensor/data', ... (211 bytes))

```

Hình 4.14. Log của broker trong kịch bản HMAC phát hiện gói tin bị sửa

Kịch bản TC-04 — Mã hóa AES-256-GCM

- Mục tiêu: bảo vệ đồng thời bí mật và toàn vẹn dữ liệu
- Thao tác: chạy chế độ encrypted ở trạng thái bình thường

Tại shell của publisher gõ “py src\publisher.py --mode encrypted --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data”

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode encrypted --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [ENCRYPTED]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"iv": "Cg9PiGLZ8wKljwms", "ciphertext": "PwbZ/Uay4as3Axd28e2u9JHmX1s96TgEOE7CM9AFo9yYcg3HnULL5H34YfOJfLSBIeZ9jiH1buC5eSyugnoLg2UHI8sk6+aoRK0aVi81niq0tjaGPi4vsSBH8wDT0mgzMp5LlNm1+vXH+IMZH6MezePni7gC2xNRKu+iAy0=", "tag": "s+HlZ0LRUGiHNgggd4zZdw==" }

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"iv": "25muwa0wIPY0vq16", "ciphertext": "qp0qOI1qIIPPFTfEmLs2P0roe6KSLmoo45FzoC7REy/MTA3h67cL4BbASUTdnf3+BoWUeBwzuStCT4ywKK1LS31uI1wSCFku7kE0DM6yN0sQaWn1V6l0GR1xkC1/gSyqIXrbCc1zeDP6AwG3HZ7zzh+SuS+ntsM0A1vnnGc=", "tag": "N+FVJyLExJ6vXLiG8j5BAG==" }

```

Hình 4.15. Publisher gửi dữ liệu ở chế độ AES-256-GCM trong kịch bản TC-04

Tại shell của subscriber gõ “py src\subscriber.py --mode encrypted --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data”

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode encrypted --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T21:12:35.449623
[*] Raw payload chụp được từ đường truyền MQTT:
{"iv": "Cg9PiGLZ8wKljwms", "ciphertext": "PwbZ/Uay4as3Axd28e2u9JHmX1s96TgE0E7CM9AFo9yYcg3HnULL5H34Yf0JfLSBIeZ9jiH1buC5eS
yugnoLg2UHI8sk6+aoRK0aVi81niq0tjaGPi4vsSBH8wDT0mgzMp5LLNm1+vXH+IMZH6MezePni7gC2xNRKu+iAy0=", "tag": "s+HLZ0LRUgiHNggd4z
Zdw=="}
=====
[+] GIẢI MÃ THÀNH CÔNG: Dữ liệu được bảo vệ an toàn (Confidentiality & Integrity)!
[+] Thiết bị ID: DHT22-SENSOR-001
[+] Nhiệt độ: 24.5°C | Độ ẩm: 60.2%
[*] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv

```

Hình 4.16. Kịch bản AES-256-GCM - mã hóa và giải mã thành công

- Kết quả quan sát: trên đường truyền chỉ là chuỗi ciphertext vô nghĩa, subscriber giải mã đúng dữ liệu gốc

```

1784902354: New connection from 192.168.1.2:51997 on port 1883.
1784902354: New client connected from 192.168.1.2:51997 as auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (p2, c1, k60, u'publisher_user').
1784902354: No will message specified.
1784902354: Sending CONNACK to auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (0, 0)
1784902354: Received PUBLISH from auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (d0, q1, r0, m1, 'iot/sensor/data', ... (247 bytes))
1784902354: Sending PUBLISH to auto-BA0AEA31-F162-729E-0E2A-C908E54D26C1 (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902354: Sending PUBACK to auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (m1, rc0)
1784902356: Received PUBLISH from auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (d0, q1, r0, m2, 'iot/sensor/data', ... (247 bytes))
1784902356: Sending PUBLISH to auto-BA0AEA31-F162-729E-0E2A-C908E54D26C1 (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902356: Sending PUBACK to auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (m2, rc0)
1784902358: Received PUBLISH from auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (d0, q1, r0, m3, 'iot/sensor/data', ... (247 bytes))
1784902358: Sending PUBLISH to auto-BA0AEA31-F162-729E-0E2A-C908E54D26C1 (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902358: Sending PUBACK to auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (m3, rc0)

```

Hình 4.17. Log của broker trong kịch bản mã hóa AES-256-GCM

Kịch bản TC-05 — AES-256-GCM phát hiện bản mã bị phá

- Mục tiêu: phát hiện khi ciphertext bị can thiệp
- Thao tác: chạy chế độ encrypted với tham số --simulate-attack

Tại shell của publisher gõ “py src\publisher.py --mode encrypted --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data”

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode encrypted --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [ENCRYPTED]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"iv": "JRZL23p+GglquQr", "ciphertext": "Zf4sQbOGqPXrzWnIN5JD5iWsmnTybuWNY8ry1/XppJNBpJ7WzrR+mw3YdZQTQL1jPdx+Wu
sxhFBsgHquORjUFlv6CSFhh8cj7B9uP6tjrl8ETCMDTPtULTIzWR1+Kf0HdI1P1eLVVreydP89xdLCwD4dftoyzkeK8cwkwci=", "tag": "Wds
FZ03CwKITVMi/0FXLVQ=="}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"iv": "T4FfF30sni7vyh2d", "ciphertext": "Wjz/onc1bg0r3yjltnuQ7s+KUBKrm0n7u3jwTvIXWcu1R0UA2hA8H4KzpnnjSLpkrDq5gU
s6kJPexVWVgLT/KjOWi9R50EVxbLLSGUZDlsrZiPeovA3sBeCHDl0MXHw1hcZ9TqHpkkGHbrJUfNi913o+aImQ7MlEGgp+RI=", "tag": "WBE
43z95s+CbVMJ2unKKWA=="}

```

Hình 4.18. Publisher gửi dữ liệu ở chế độ AES-256-GCM trong kịch bản TC-05

Tại shell của subscriber gõ “py src\subscriber.py --mode encrypted --simulate-attack --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data”

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode encrypted --simulate-attack --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T21:17:34.790533
[*] Raw payload chụp được từ đường truyền MQTT:
{"iv": "JRZL23p+GglquuQr", "ciphertext": "Zf4sQb0GqPXrzWnIN5JD5iWsmnTybuWNY8ry1/XppJNBpJ7WzrR+mw3YdZQTQL1jPdx+WusxhfBsgHquORjUFlv6CSFhh8cj7B9uP6tjrl8ETCMDTPtULTIzWR1+Kf0HdI1PleLVVreydP89xdlCwD4df toyzkeK8cwkwcI=", "tag": "WdsFZ03CWKITVMi/0FXlVQ==" }
=====
[!] Tấn công giả lập: Đang phá hoại chuỗi ciphertext mã hóa...
[-] LỖI GIẢI MÃ: Kẻ tấn công đã sửa đổi gói tin hoặc khóa không đúng! Chi tiết: Giải mã thất bại hoặc dữ liệu đã bị sửa đổi trái phép! Chi tiết:
[*] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv

```

Hình 4.19. Kịch bản AES-256-GCM phát hiện ciphertext bị sửa

- Kết quả quan sát: subscriber báo "LỖI GIẢI MÃ" và không lấy được dữ liệu.

```

1784902653: New connection from 192.168.1.2:58968 on port 1883.
1784902653: New client connected from 192.168.1.2:58968 as auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (p2, c1, k60, u'publisher_user').
1784902653: No will message specified.
1784902653: Sending CONNACK to auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (0, 0)
1784902653: Received PUBLISH from auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (d0, q1, m1, 'iot/sensor/data', ... (247 bytes))
1784902653: Sending PUBLISH to auto-57D68438-3B9C-AA7D-E985-484D4FB638AD (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902653: Sending PUBACK to auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (m1, rc0)
1784902655: Received PUBLISH from auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (d0, q1, r0, m2, 'iot/sensor/data', ... (247 bytes))
1784902655: Sending PUBLISH to auto-57D68438-3B9C-AA7D-E985-484D4FB638AD (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902655: Sending PUBACK to auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (m2, rc0)
1784902657: Received PUBLISH from auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (d0, q1, r0, m3, 'iot/sensor/data', ... (247 bytes))
1784902657: Sending PUBLISH to auto-57D68438-3B9C-AA7D-E985-484D4FB638AD (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902657: Sending PUBACK to auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (m3, rc0)

```

Hình 4.20. Log của broker trong kịch bản AES-256-GCM phát hiện bản mã bị phá

Ba kịch bản TC-06 đến TC-08 được thực hiện trên broker Mosquitto cục bộ (chạy trên máy ảo Ubuntu) đã bật xác thực username/password và danh sách kiểm soát truy cập (ACL) — những tính năng mà broker công khai không cho phép cấu hình. Broker được chạy ở chế độ hiển thị log chi tiết (mosquitto -c configs/mosquitto.conf -v) nhằm ghi nhận các sự kiện kết nối và từ chối.

Kịch bản TC-06 — Xác thực hợp lệ trên broker cục bộ

- Mục tiêu: xác nhận hệ thống hoạt động đúng khi client sử dụng tài khoản hợp lệ.
- Thao tác: chạy publisher với tài khoản publisher_user (quyền ghi) và subscriber với tài khoản subscriber_user (quyền đọc), cùng trở về broker cục bộ bằng --broker <IP_may_ao> kèm --username và --password.
- Kết quả quan sát: broker chấp nhận kết nối (gói CONNACK trả mã 0), publisher gửi và subscriber nhận được dữ liệu bình thường.

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --broker 192.168.1.6 --username subscriber_user --password 123 --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

```

Hình 4.21. Subscriber kết nối đến broker cục bộ thành công, có xác thực username/password

```

PS C:\Users\USER> cd "D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki"
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --broker 192.168.1.6 --username publisher_user --password 123 --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [CLEARTEXT]...

```

Hình 4.22. Publisher kết nối hợp lệ qua broker cục bộ có xác thực username/password

Kịch bản TC-07 — Chặn kết nối sai thông tin đăng nhập

- Mục tiêu: chứng minh broker từ chối client không có tài khoản hợp lệ, chống giả mạo danh tính.
- Thao tác: chạy client với cặp username/password không hợp lệ để mô phỏng kẻ giả mạo. Ở đây nhập sai password. (Pass đúng là 123 như các ảnh trên nhưng em đã cố tình đặt sai pass là “saibet”).
- Kết quả quan sát: broker từ chối kết nối, client báo “Kết nối thất bại, mã trả về: Not authorized” và không có dữ liệu nào được trao đổi.

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --broker 192.168.1.6 --username subscriber_user --password saibet --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[-] Kết nối thất bại, mã trả về: Not authorized
[-] Kết nối thất bại, mã trả về: Not authorized
[-] Kết nối thất bại, mã trả về: Not authorized
[-] Kết nối thất bại, mã trả về: Not authorized

[*] Dừng subscriber.
[*] Đã ngắt kết nối.
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki>
```

Hình 4.23. Broker từ chối kết nối do sai thông tin đăng nhập

Kịch bản TC-08 — Phân quyền ACL chặn ghi trái phép

- Mục tiêu: chứng minh cơ chế ACL ngăn tài khoản chỉ có quyền đọc thực hiện thao tác ghi, chống vượt quyền.
- Thao tác: dùng tài khoản subscriber_user (chỉ có quyền đọc) cố gắng publish lên topic iot/sensor/data.
- Kết quả quan sát: broker chấp nhận đăng nhập nhưng từ chối lệnh publish, ghi log Denied PUBLISH kèm mã lý do 135 (Not Authorized); subscriber hợp lệ không nhận được gói tin nào.

```
Windows PowerShell x + v
Payload gửi đi:
{"timestamp": "2026-07-09T15:41:35Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.7, "humidity": 61.4, "status": "OK"}
[*] Đã ngắt kết nối.
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> ^C
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --broker 192.168.1.6 --username subscriber_user --password 123 --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[*] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [CLEARTEXT]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "status": "OK"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "status": "OK"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity": 60.0, "status": "OK"}

[Gửi gói tin #4] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:15Z", "device_id": "DHT22-SENSOR-001", "temperature": 25.0, "humidity": 59.8, "status": "OK"}

Windows PowerShell x + v
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --broker 192.168.1.6 --username subscriber_user --password 123 --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[*] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data
```

Hình 4.24. Cơ chế ACL chặn thao tác ghi trái phép trên broker cục bộ

Bên máy Guest (VM-Ubuntu) đóng vai trò broker, ta nhập lệnh “cat results/logs/mosquitto.log” để show ra log của broker ra màn hình.

```

1784871264: Sending CONNACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (0, 0)
1784871264: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m1, 'iot/sensor/data', ... (125 bytes))
1784871264: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m1, rc135)
1784871266: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m2, 'iot/sensor/data', ... (125 bytes))
1784871266: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m2, rc135)
1784871268: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m3, 'iot/sensor/data', ... (125 bytes))
1784871268: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m3, rc135)
1784871270: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m4, 'iot/sensor/data', ... (125 bytes))
1784871270: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m4, rc135)
1784871272: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m5, 'iot/sensor/data', ... (125 bytes))
1784871272: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m5, rc135)
1784871274: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m6, 'iot/sensor/data', ... (125 bytes))
1784871274: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m6, rc135)
1784871276: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m7, 'iot/sensor/data', ... (125 bytes))
1784871276: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m7, rc135)
1784871276: Received DISCONNECT from auto-9628C074-E1A9-1DD8-A770-EDE1809A073A
1784871276: Client auto-9628C074-E1A9-1DD8-A770-EDE1809A073A disconnected.
1784871278: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m8, 'iot/sensor/data', ... (130 bytes))
1784871278: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m8, rc135)
1784871280: Received DISCONNECT from auto-72F19391-B9FA-A4FE-892E-F980146D67AF
1784871280: Client auto-72F19391-B9FA-A4FE-892E-F980146D67AF disconnected.

```

Hình 4.25. Log broker ghi nhận "Denied PUBLISH from subscriber_user" kèm mã lý do 135

4.4. Kết quả

Đề tài đã hoàn thành demo MQTT với ba chế độ bảo vệ dữ liệu và chạy được tám kịch bản thử nghiệm (năm kịch bản bảo vệ dữ liệu và ba kịch bản xác thực/phân quyền trên broker cục bộ). Các kết quả chính gồm:

- Ở chế độ cleartext, toàn bộ payload (device_id, nhiệt độ, độ ẩm) hiển thị dạng rõ trên đường truyền; log subscriber và ảnh chụp cho thấy dữ liệu bị đọc trực tiếp.
- Ở chế độ HMAC-SHA256, dữ liệu vẫn đọc được nhưng khi gói tin bị sửa, subscriber phát hiện ngay do chữ ký không khớp.
- Ở chế độ AES-256-GCM, dữ liệu trên đường truyền chỉ còn chuỗi Base64 vô nghĩa; khi ciphertext bị can thiệp, giải mã báo lỗi nhờ authentication tag.
- Ở tầng broker cục bộ, việc bật xác thực username/password và ACL đã chặn được kẻ giả mạo: sai thông tin đăng nhập bị từ chối kết nối (Not authorized), còn tài khoản chỉ có quyền đọc bị chặn khi cố ghi (Denied PUBLISH).

Kết quả cho thấy rõ sự khác biệt giữa ba mức bảo vệ dữ liệu, đồng thời chứng minh hiệu quả của cơ chế xác thực và phân quyền ở tầng broker — đúng như mục tiêu đề ra.

Bảng 4.2. Tổng hợp kết quả các kịch bản kiểm thử

Tiêu chí	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng
Bảo mật khi truyền thô	Dữ liệu rõ dễ bị lộ	Đọc được toàn bộ JSON trên đường truyền	Đạt	cleartext_demo.png
Toàn vẹn (HMAC)	Phát hiện sửa đổi	Báo HMAC thất bại khi gói tin bị sửa	Đạt	hmac_attack.png
Bí mật (AES-GCM)	Che giấu nội dung	Đường truyền chỉ còn ciphertext	Đạt	aes_ok.png
Chống phá mã (AES tag)	Phát hiện ciphertext bị sửa	Báo lỗi giải mã khi bị can thiệp	Đạt	aes_attack.png

Ghi nhận dữ liệu	Lưu log và kết quả	Có log và output.csv cho các chế độ	Đạt	results/logs, output.csv
Xác thực broker	Chặn client không hợp lệ	Sai username/mật khẩu bị từ chối kết nối (Not authorized)	Đạt	TC-07 (Hình 4.23)
Phân quyền ACL	Chặn ghi trái phép	Tài khoản chỉ có quyền đọc bị chặn khi publish (Denied PUBLISH)	Đạt	spoofing_blocked (Hình 4.24)

Đối chiếu với tám tiêu chí đã đặt ở Mục 3.5: TĐ-01 đạt, cả 8/8 kịch bản cho kết quả đúng kỳ vọng. TĐ-02 đạt, chế độ cleartext đọc được cả bốn trường dữ liệu trên đường truyền còn chế độ AES-256-GCM không đọc được trường nào. TĐ-03 và TĐ-04 đạt, mọi bản tin bị can thiệp đều bị phát hiện và không có bản tin hợp lệ nào bị báo sai. TĐ-05 và TĐ-06 đạt, broker trả rc = 0 với tài khoản hợp lệ, trả "Not authorized" khi sai mật khẩu và ghi "Denied PUBLISH" kèm mã 135 khi tài khoản chỉ có quyền đọc cố ghi. TĐ-07 đạt, mỗi kịch bản đều có ảnh chụp và log tương ứng trong thư mục results. TĐ-08 đạt, toàn bộ rủi ro mức Cao đều giảm về Trung bình hoặc Thấp, chi tiết ở Bảng 5.4.

4.5. Thảo luận và hạn chế

4.5.1. Thảo luận kết quả so với mục tiêu

Đối chiếu với bốn mục tiêu MT-01 đến MT-04 nêu ở Mục 1.3:

- MT-01 (minh họa rủi ro cleartext): đạt — kịch bản TC-01 cho thấy dữ liệu rõ bị đọc trực tiếp.
- MT-02 (demo publisher/subscriber bằng Paho): đạt — mã nguồn trong thư mục src chạy được trên broker thật.
- MT-03 (so sánh ba chế độ): đạt — thể hiện qua Bảng 4.2 và log thực nghiệm.
- MT-04 (phân tích đe dọa và biện pháp): đạt — trình bày ở Chương 5 và được kiểm chứng thực tế qua nhóm kịch bản xác thực/ACL (TC-06 đến TC-08).

4.5.2. Hạn chế

Đề tài còn một số hạn chế:

- Dữ liệu là giả lập, chưa lấy từ cảm biến vật lý thật.
- Kênh truyền chưa bật TLS ở tầng vận chuyển; dữ liệu mới được bảo vệ ở mức payload (HMAC/AES-GCM) và kiểm soát truy cập tại broker.
- Việc sửa đổi gói tin được mô phỏng bằng cờ --simulate-attack ở phía nhận, chưa phải tấn công xen giữa (MITM) thực tế trên đường truyền.
- Khóa HMAC/AES đặt trong mã nguồn nên chỉ phù hợp môi trường học tập, chưa có quản lý khóa an toàn.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu cần bảo vệ

Bảng 5.1. Tài sản và dữ liệu cần bảo vệ

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Dữ liệu cảm biến (nhiệt độ, độ ẩm)	Người dùng thiết bị	Cao	C, I	Lộ ra tiết lộ thói quen, tình trạng thiết bị
Định danh thiết bị (device_id)	Hệ thống giám sát	Trung bình	I, A	Bị giả mạo gây dữ liệu sai
Khóa HMAC/AES	Nhóm phát triển	Cao	C	Lộ khóa mất toàn bộ khả năng bảo vệ
Tài khoản broker (user/pass)	Quản trị broker	Cao	C, I	Lộ dẫn tới publish/subscribe trái phép
Log và dữ liệu nhận (output.csv)	Hệ thống giám sát	Trung bình	I	Dùng để phân tích, cần giữ toàn vẹn

5.2. Môi đe dọa và lỗ hổng

Bảng 5.2. Môi đe dọa và lỗ hổng theo mô hình STRIDE

ID	Tài sản	Môi đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-01	Dữ liệu cảm biến	Nghe lén (eavesdropping)	Payload truyền dạng cleartext	Lộ thông tin riêng tư	TC-01, OWASP ISVS
T-02	Dữ liệu cảm biến	Sửa đổi (tampering)	Thiếu cơ chế kiểm tra toàn vẹn	Dữ liệu sai lệch, báo động giả	TC-03, RFC 2104
T-03	Định danh thiết bị	Giả mạo (spoofing)	Broker không xác thực/ACL	Thiết bị giả gửi dữ liệu	TC-08, configs/aclfile
T-04	Dữ liệu cảm biến	Phát lại (replay)	Không kiểm tra timestamp/nonce	Gửi lại dữ liệu cũ	Phân tích STRIDE
T-05	Khóa HMAC/AES	Lộ khóa	Khóa hardcoded trong mã nguồn	Mất khả năng bảo vệ	src/utlis.py
T-06	Tài khoản broker	Truy cập trái phép	Mật khẩu yếu hoặc dùng chung	Publish/subscribe trái phép	TC-07, configs/passwd

5.3. Ma trận rủi ro

Điểm rủi ro được tính bằng công thức Điểm = Khả năng x Tác động, với thang phân loại: 1-4 là Thấp, 5-9 là Trung bình, 10-16 là Cao và 17-25 là Nghiêm trọng. Sáu rủi ro R-01 đến R-06 tương ứng với sáu mối đe dọa T-01 đến T-06 ở Bảng 5.2. Vị trí của từng rủi ro trên ma trận 5x5 được thể hiện ở Bảng 5.3.

Bảng 5.3. Ma trận rủi ro 5x5 (khả năng x tác động)

Khả năng \ Tác động	1 - Rất thấp	2 - Thấp	3 - Trung bình	4 - Cao	5 - Rất cao
5 - Rất cao					
4 - Cao				R-01	
3 - Trung bình			R-06	R-02, R-03	
2 - Thấp			R-04		R-05
1 - Rất thấp					

Bảng 5.4. Sổ đăng ký rủi ro và mức rủi ro còn lại sau xử lý

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	4	4	16	Cao	Mã hóa AES-GCM hoặc bật TLS	Thấp
R-02	3	4	12	Cao	HMAC-SHA256 hoặc AES tag	Thấp
R-03	3	4	12	Cao	Username/password và ACL	Trung bình
R-04	2	3	6	Trung bình	Thêm timestamp/nonce	Trung bình
R-05	2	5	10	Cao	Quản lý khóa ngoài mã, xoay khóa	Trung bình
R-06	3	3	9	Trung bình	Mật khẩu mạnh, ACL tối thiểu	Thấp

5.4. Biện pháp giảm thiểu

Thứ tự ưu tiên biện pháp theo mức rủi ro:

- Ưu tiên cao: mã hóa AES-256-GCM ở payload (hoặc TLS ở tầng vận chuyển) để chống nghe lén và sửa đổi — chủ thể: nhóm phát triển, độ khó thấp.

- Ưu tiên cao: bật xác thực username/password và ACL trên broker để chống giả mạo — đã triển khai trên broker Mosquitto cục bộ và kiểm chứng qua TC-06 đến TC-08 (chủ thể: quản trị broker, độ khó trung bình).
- Ưu tiên trung bình: quản lý khóa ngoài mã nguồn (biến môi trường hoặc kho khóa) và xoay khóa định kỳ để chống lộ khóa.
- Ưu tiên trung bình: thêm timestamp/nonce vào payload để chống tấn công phát lại.

5.5. Rủi ro còn lại

Sau khi áp dụng mã hóa AES-GCM và bật xác thực cùng ACL trên broker cục bộ (đã kiểm chứng thực tế qua TC-06 đến TC-08), các rủi ro nghe lén, sửa đổi và giả mạo giảm xuống mức thấp. Rủi ro còn lại chủ yếu là quản lý khóa và tấn công phát lại, ở mức chấp nhận được trong phạm vi môi trường học tập. Nếu triển khai thực tế cần theo dõi và bổ sung: bật TLS, dùng kho khóa an toàn, và thêm cơ chế chống phát lại.

Các rủi ro còn lại được chấp nhận trong phạm vi môi trường học tập, nhưng phải được xem xét lại ngay khi xuất hiện một trong các điều kiện sau: hệ thống chuyển sang dùng dữ liệu cảm biến thật của người dùng; broker được mở ra ngoài phạm vi mạng nội bộ; số thiết bị hoặc số tài khoản tăng lên khiến việc dùng chung một khóa không còn an toàn; hoặc phát sinh yêu cầu lưu trữ và truy vết dữ liệu lịch sử phục vụ mục đích vận hành.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Đề tài đã xây dựng thành công một demo MQTT minh họa rõ rủi ro nghe lén dữ liệu cảm biến khi truyền dạng thô, kiểm chứng hai lớp bảo vệ dữ liệu HMAC-SHA256 và AES-256-GCM, đồng thời triển khai xác thực và phân quyền (ACL) ở tầng broker cục bộ — tất cả qua tám kịch bản thử nghiệm có log và ảnh minh chứng. Kết quả cho thấy AES-GCM bảo vệ đồng thời tính bí mật và toàn vẹn, HMAC đảm bảo toàn vẹn khi cần giữ dữ liệu ở dạng đọc được, còn xác thực kết hợp ACL ngăn được truy cập và ghi trái phép trên broker. Bốn mục tiêu đề ra ở Mục 1.3 đều đạt; đề tài hoàn thành tốt phần thực nghiệm cốt lõi.

6.2. Hạn chế

Đề tài có bốn hạn chế chính, đã trình bày chi tiết ở Mục 4.5.2. Thứ nhất, dữ liệu cảm biến là dữ liệu giả lập nên chưa phản ánh nhiều và độ trễ của thiết bị vật lý. Thứ hai, kênh truyền chưa bật TLS ở tầng vận chuyển; dữ liệu mới được bảo vệ ở mức payload và bằng kiểm soát truy cập tại broker. Thứ ba, việc sửa đổi bản tin được mô phỏng bằng cờ --simulate-attack ở phía nhận nên chưa phải một tấn công xen giữa thực tế trên đường truyền. Thứ tư, khóa HMAC và AES còn nằm trong mã nguồn nên chỉ phù hợp môi trường học tập. Những hạn chế này không làm thay đổi kết luận về hiệu quả tương đối của ba mức bảo vệ, nhưng cần được xử lý trước khi áp dụng vào hệ thống thật.

6.3. Hướng phát triển

Một số hướng phát triển tiếp theo:

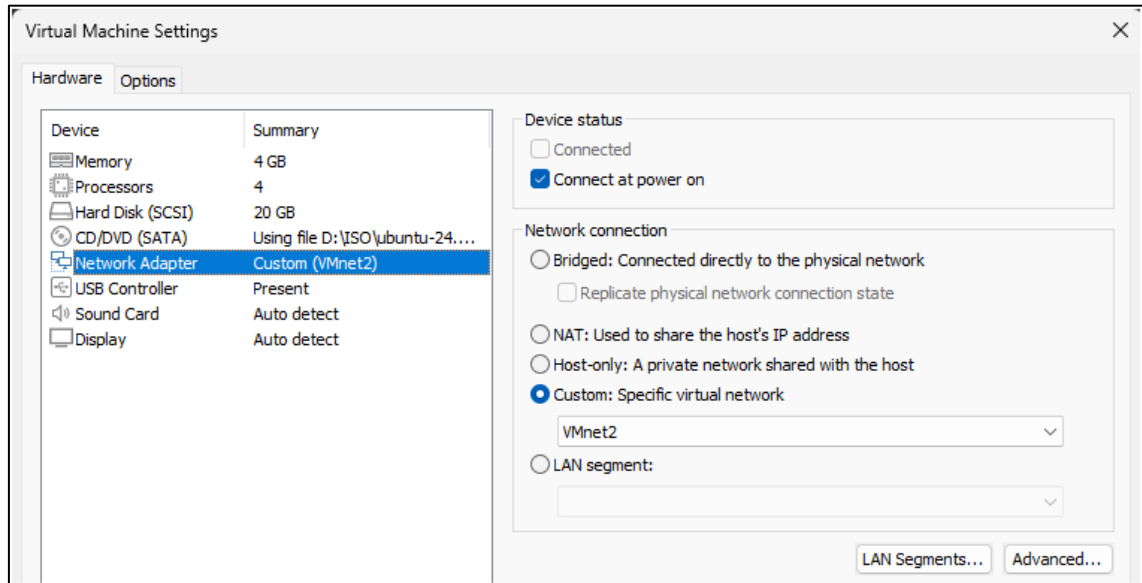
- Bật TLS/SSL ở tầng vận chuyển (cổng 8883) để mã hóa toàn bộ kênh MQTT, bổ sung cho lớp bảo vệ payload và xác thực broker đã có.
- Đưa khóa ra khỏi mã nguồn, dùng biến môi trường hoặc kho khóa kèm cơ chế xoay khóa định kỳ.
- Thêm timestamp/nonce để chống tấn công phát lại (replay).
- Mở rộng với thiết bị và cảm biến thật (ESP32, Raspberry Pi) và nhiều loại dữ liệu hơn.

TÀI LIỆU THAM KHẢO

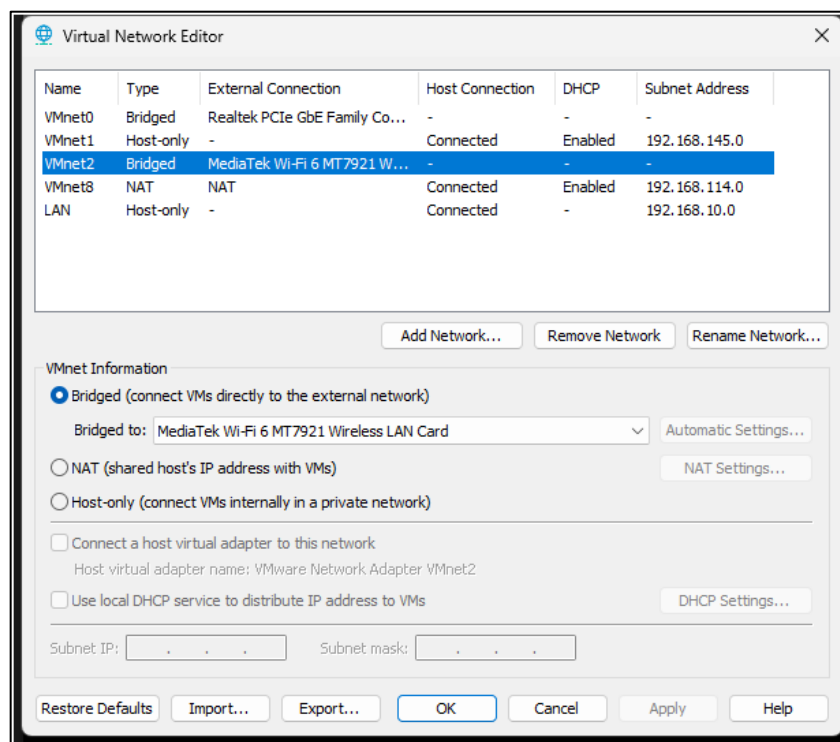
- [1] Eclipse Foundation. Eclipse Mosquitto. <https://github.com/eclipse-mosquitto/mosquitto>. Truy cập ngày 17/07/2026.
- [2] Eclipse Foundation. Eclipse Paho Python Client. <https://github.com/eclipse-paho/paho.mqtt.python>. Truy cập ngày 17/07/2026.
- [3] OWASP Foundation. IoT Security Verification Standard (ISVS). <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Truy cập ngày 17/07/2026.
- [4] IETF. RFC 2104 - HMAC: Keyed-Hashing for Message Authentication. <https://datatracker.ietf.org/doc/html/rfc2104>. Truy cập ngày 17/07/2026.
- [5] NIST. SP 800-38D - Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM). <https://csrc.nist.gov/publications/detail/sp/800-38d/final>. Truy cập ngày 17/07/2026.
- [6] OASIS. MQTT Version 5.0 Specification. <https://docs.oasis-open.org/mqtt/mqtt/v5.0/mqtt-v5.0.html>. Truy cập ngày 17/07/2026.

PHỤ LỤC

1. Cài đặt máy ảo Ubuntu



Hình 1. Cấu hình của máy ảo Ubuntu



Hình 2. Setting của các Vmnet trong máy

Ở đây em dùng Vmnet2 đang set chế độ bridge của card wifi máy thật. Và thêm card Vmnet2 này cho máy ảo ubuntu bên trên. Từ đó máy ảo ubuntu và máy windows thật bên ngoài có thể thiết lập thành mô hình Publisher/Subscriber ⇔ Broker.

```
Ubuntu 24.04.4 LTS huy tty1
huy login: huy
Password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-136-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sun Aug  2 09:37:01 AM UTC 2026

System load:  0.04               Processes:            266
Usage of /:   47.9% of 9.75GB    Users logged in:     0
Memory usage: 7%                IPv4 address for ens33: 192.168.1.8
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

32 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

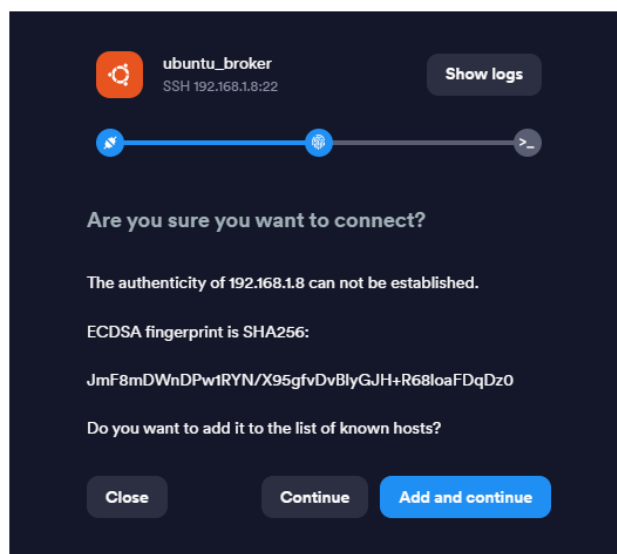
8 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

huy@huy:~$ _
```

Hình 3. Giao diện máy ảo Ubuntu khi login

Sau khi vào được thì em sẽ dùng lệnh **ip a** để lấy ip máy và lệnh **sudo systemctl start ssh** để chạy ssh, dùng phần mềm Termius để SSH vào để tiện copy lệnh trong quá trình thực nghiệm.



Hình 4. Đăng nhập qua ssh

```
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-136-generic x86_64)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/pro

System information as of Sun Aug  2 09:40:48 AM UTC 2026

System load:  0.01               Processes:            232
Usage of /:   48.0% of 9.75GB    Users logged in:     1
Memory usage: 7%                IPv4 address for ens33: 192.168.1.8
Swap usage:   0%

* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

32 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

8 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Fri Jul 24 15:07:52 2026 from 192.168.1.2
huy@huy:~$
```

Hình 5. Giao diện sau khi vào phần mềm termius.

2. Cài đặt Mosquitto

Chạy lệnh **sudo apt update && sudo apt install -y mosquitto mosquitto-clients** bắt đầu cài đặt.

```
Last login: Fri Jul 24 15:07:52 2026 from 192.168.1.2
huy@huy:~$ sudo apt update && sudo apt install -y mosquitto mosquitto-clients
```

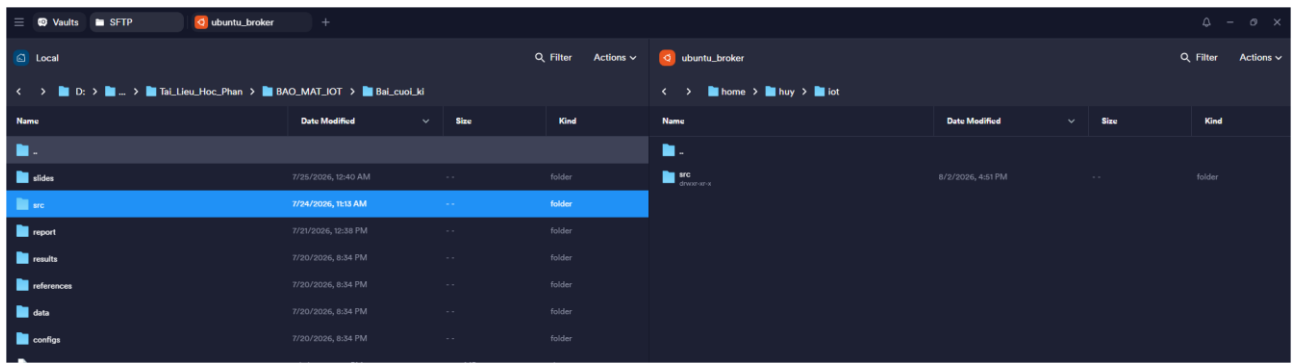
Hình 6. Chạy lệnh cài đặt Mosquitto

```
42 packages can be upgraded. Run 'apt list --upgradable' to see them.
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
mosquitto is already the newest version (2.0.18-1build3).
mosquitto-clients is already the newest version (2.0.18-1build3).
The following packages were automatically installed and are no longer required:
  geoip-database libgeoip1t64 libmysqlclient21 mysql-common net-tools
Use 'sudo apt autoremove' to remove them.
0 upgraded, 0 newly installed, 0 to remove and 42 not upgraded.
huy@huy:~$
```

Hình 7. Mosquitto cài đặt thành công

Bước tiếp theo là lấy mã nguồn về để chạy thực nghiệm các kịch bản thì có 2 cách để lấy mã nguồn:

Nhập “git clone https://github.com/huytvh059/De_tai_27-Nghe_len_du_lieu_trong_mang_IoT.git” để pull mã nguồn từ repo. Nhưng ở đây em có mã nguồn sẵn ở máy nên sẽ dùng tính năng SFTP của termius để đưa code vào VM Ubuntu (tương tự như winscp).



Hình 8. Mã nguồn được đưa vào máy ubuntu.

```
huy@huy:~/iot$ ls
src
huy@huy:~/iot$ cd src
huy@huy:~/iot/src$ ls
publisher.py  __pycache__  subscriber.py  utils.py
huy@huy:~/iot/src$
```

Hình 9. Mã nguồn được đưa vào máy ubuntu.

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

Mã nguồn và toàn bộ minh chứng của đề tài được tổ chức trong repo GitHub *huytvh059/De_tai_27-Nghe_len_du_lieu_trong_mang_IoT* theo cấu trúc dưới đây:

```
De_tai_27-Nghe_len_du_lieu_trong_mang_IoT/
├── README.md                # Mô tả đề tài, cấu trúc thư mục và cách chạy
├── requirements.txt          # Thư viện Python cần cài (paho-mqtt, cryptography)
├── src/                      # Mã nguồn Python
│   ├── publisher.py         # Cảm biến giả lập: đọc CSV, gửi payload 3 chế độ
│   ├── subscriber.py        # Bên nhận: kiểm HMAC / giải mã AES, ghi log
│   └── utils.py             # HMAC-SHA256, AES-256-GCM, canonical_json
├── configs/                 # Cấu hình broker Mosquitto cục bộ
│   ├── mosquitto.conf      # Bật xác thực và ACL, cấu hình log
│   ├── aclfile              # publisher_user: ghi, subscriber_user: đọc
│   └── passwd               # File mật khẩu (tạo bằng mosquitto_passwd)
├── data/                    # Dữ liệu đầu vào
│   ├── dataset_gia_lap.csv  # Dữ liệu DHT22 giả lập (nhiệt độ, độ ẩm)
│   └── payload_mau.json     # Bản tin mẫu trước và sau khi bảo vệ
├── results/                 # Kết quả thực nghiệm - minh chứng
│   ├── logs/               # Log lưu lượng phía client
│   │   ├── cleartext_traffic.log # Log kịch bản TC-01
│   │   └── secure_traffic.log   # Log kịch bản TC-02 đến TC-05
│   ├── output.csv          # Dữ liệu subscriber nhận + trạng thái toàn vẹn
│   └── screenshots/        # 10 ảnh chụp terminal các kịch bản
├── report/                  # Báo cáo
│   ├── 231A010454_ThiVoHoangHuy_DeTai27_TieuLuan_CuoiKy.docx
│   └── 231A010454_ThiVoHoangHuy_DeTai27_TieuLuan_CuoiKy.pdf
├── slides/                  # Slide thuyết trình
│   ├── 231A010454_ThiVoHoangHuy_DeTai27_Slide.pptx.pptx
│   └── 231A010454_ThiVoHoangHuy_DeTai27_Slide.pdf
├── references/              # Nguồn tham khảo
└── link_nguon.md
```

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

STT	Họ tên - MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1	Thi Võ Hoàng Huy – 231A010454	Nghiên cứu, soạn báo cáo, thiết kế lab, thực nghiệm	README, docs, report, results.	100%	100%

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ 7 phần chính, mục lục và tài liệu tham khảo.	☒ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	☒ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	☒ Đạt ☐ Chưa đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh.	☒ Đạt ☐ Chưa đạt

STT	Nội dung kiểm tra	Trạng thái
5	Có ít nhất 3 minh chứng kiểm tra được trong results/ hoặc báo cáo.	☒ Đạt ☐ Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	☒ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phân phân tích.	☒ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	☒ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	☒ Đạt ☐ Chưa đạt
10	Slide có 8-12 trang, link repo, kết quả chính, rủi ro và kết luận.	☒ Đạt ☐ Chưa đạt
11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	☒ Đạt ☐ Chưa đạt